MASTER THESIS

Attack Detection in Encrypted TLS 1.3 / QUIC Traffic

submitted by: **Vandit Prameshbhai Shah**
(Student Number: 200443)

submitted on: **07.02.2026**

Examiner: **HDBW Prüfungsamt**

Supervisor: **Prof. Dr. Jianmin Chen**
(HDBW München)

Munich, Germany

Eidesstattliche Erklärung / Affidavit

Hiermit versichere ich, dass die vorliegende Arbeit ohne Hilfe Dritter und nur mit den angegebenen Quellen und Hilfsmitteln angefertigt wurde. Alle verwendeten Passagen wurden kenntlich gemacht. Diese Arbeit hat in gleicher oder ähnlicher Form noch keiner Prüfungsbehörde vorgelegen.

München, 05.02.2026	vanditshah
Ort, Datum	Unterschrift

First Name, Surname - Vandit Prameshbhai Shah

Abstract

Encrypted network traffic secured by protocols such as TLS 1.3 and QUIC presents substantial challenges for security monitoring due to the concealment of payload and handshake metadata. This work addresses detection of malicious activities, including command-and-control communications and data exfiltration, by analyzing flow-level metadata exclusively, thereby preserving user privacy and complying with legal constraints. It explores feature engineering strategies focusing on timing characteristics, packet size distributions, and directional asymmetries observable despite encryption. Machine learning models, specifically Naive Bayes, Random Forest, and Gradient Boosting, are evaluated for their effectiveness in classifying encrypted flows using these features. The methodology incorporates multi-tier classification architectures and graph-based relational analyses to enhance detection accuracy and resilience against adversarial evasion tactics. Experimental evaluation employs a combination of public datasets and controlled laboratory-generated traffic, ensuring reproducibility and realistic noise conditions. Ethical considerations and GDPR compliance guide data handling and feature selection, emphasizing anonymization and minimization of identifiable information. Challenges such as multiplexed QUIC streams, protocol evolution, and operational scalability are addressed through adaptive preprocessing and model retraining. Results demonstrate that flow-level statistical analysis combined with machine learning can identify covert malicious behaviors within encrypted traffic without breaching confidentiality, offering a privacy-respecting approach to network security monitoring in encrypted environments.

Contents

Eidesstattliche Erklärung 1

List of Figures **3**

List of Tables **4**

1 Introduction and Motivation **5**

2 Background and Fundamentals **8**
2.1 Encrypted Network Traffic 8
2.1.1 Definition and Characteristics 8
2.1.2 Challenges in Traffic Analysis 10
2.2 TLS 1.3 and QUIC Protocols 12
2.2.1 Protocol Overview 12
2.2.2 Security Features and Limitations 14
2.3 Flow-Level Analysis 16

3 Threat Model and Encrypted Threat Landscape **20**
3.1 Types of Malicious Activities 20
3.1.1 Command-and-Control Communications 20
3.1.2 Data Exfiltration 22
3.2 Defense Challenges 24

4 Related Work and State of the Art **28**
4.1 Machine Learning in Encrypted Traffic Analysis 28
4.2 Flow-Based Statistical Methods 30

5 Dataset Design and Traffic Collection **33**
5.1 Public Datasets 34
5.2 Controlled Laboratory Traffic 35

6 Feature Engineering and System Architecture **39**
6.1 Flow-Based Features 39
6.1.1 Timing Characteristics 39
6.1.2 Packet Size Distributions 42
6.2 System Architecture 44

7 Machine Learning Methodology **47**
7.1 Experimental Setup . . . 47
7.1.1 Dataset Generation and Description . . . 47
7.1.2 Feature Extraction and Engineering Pipeline . . . 48
7.1.3 Hardware and Software Infrastructure . . . 48
7.1.4 Training and Testing Methodology . . . 49
7.2 Model Selection . . . 49
7.2.1 Naive Bayes . . . 49
7.2.2 Random Forest . . . 52
7.3 Evaluation Metrics . . . 54
7.3.1 Discussion and Research Implications . . . 61

8 Ethical, Legal, and Privacy Considerations **63**
8.1 GDPR Compliance . . . 63
8.2 Balancing Security and Privacy . . . 66

9 Threats to Validity **69**
9.1 Internal Validity . . . 69
9.2 External Validity . . . 71

10 Conclusion **74**
Annex . . . 79
Tools and Software Used . . . 79
Zeek Network Security Monitor . . . 79
CICFlowMeter . . . 79
Datasets . . . 80
GitHub Repository . . . 80
Ethical and Legal Considerations . . . 80

List of Figures

3.1 Threat model overview for attack detection in encrypted TLS 1.3 and QUIC traffic. The monitoring point observes only flow-level metadata (e.g., timing, sizes, and directionality), while payload content remains encrypted. 25

5.1 Data collection and labeling workflow combining public datasets and controlled laboratory traffic, followed by preprocessing, feature extraction, labeling, and train/test splitting. 38

6.1 System architecture and processing pipeline for encrypted traffic analysis. Captured TLS 1.3 and QUIC flows are preprocessed, transformed into flow-level features, analyzed by machine learning models, and logged as benign or malicious without payload decryption. 44

6.2 Illustration of an encrypted network flow represented as a fixed-length feature vector composed of flow-level statistics. Each feature captures timing, size, directionality, or burst-related characteristics observable without payload decryption. 46

7.1 confusion matrix for the Random Forest classifier on encrypted TLS 1.3 and QUIC traffic,classification behavior on a single evaluation fold. 55

7.2 Receiver Operating Characteristic (ROC) curve for encrypted traffic attack detection using the Random Forest classifier, evaluated on the held-out test set. 59

7.3 Precision–Recall (PR) curve for encrypted traffic attack detection using the Random Forest classifier (held-out test set). PR-AUC is reported in addition to ROC-AUC because it is more informative under class imbalance. 60

7.4 Comparison of F1-scores across evaluated classifiers for encrypted traffic detection. Ensemble models (RF and GB) outperform the Naive Bayes baseline by capturing non-linear relationships among flow-level features. 61

List of Tables

2.1 Passive visibility comparison: TLS 1.2 vs TLS 1.3 vs QUIC (TLS 1.3 over UDP). 13
2.2 Flow-level feature categories for encrypted traffic analysis. 18

3.1 Threat types and expected flow-level metadata signals in encrypted TLS 1.3 / QUIC traffic. 20

4.1 Comparison of related work on attack detection in encrypted network traffic. . 28

5.1 Overview of public datasets and repositories used or referenced for building encrypted-traffic detection experiments. 33
5.2 Traffic collection setup for controlled laboratory experiments. 36

6.1 Final grouped feature set extracted from encrypted TLS 1.3 and QUIC flows. 39
6.2 Compact definitions and detection intuition for core flow-level features. 41

7.1 Summary of machine learning models evaluated for encrypted traffic classification. 49
7.2 Definition and interpretation of evaluation metrics used in encrypted traffic classification. 54
7.3 Representative classification performance (mean $\pm$ std.) across 5-fold cross-validation for encrypted traffic detection. 57

8.1 Privacy-preserving design choices adopted in this thesis. 63

Chapter 1

Introduction and Motivation

Encrypted network traffic has posed a persistent challenge for network security monitoring, as traditional payload-centric inspection methods lose efficacy when encryption protocols such as TLS 1.3 and QUIC protect both the data content and key protocol parameters. Relying on decryption via SSL key extraction or deep packet inspection is either impractical in high-throughput networks or undesirable for privacy preservation. This work focuses on analyzing only flow-level metadata to detect malicious activities like command-and-control communication and data exfiltration, activities that often hide within otherwise normal-seeming encrypted flows. Earlier approaches to application detection in encrypted traffic typically fell into two categories: statistical feature analysis based on aggregate traffic properties and graph-based modeling of communication patterns among entities (Shah, Ahmed, and Nagaraja 2022a). While insightful, those methods struggled against modern encryption schemes that obscure packet payloads and much of the handshake information. Machine learning offers a pathway to overcome these limitations by leveraging patterns embedded in side-channel features such as flow durations, packet sizes, timing distributions, and TLS handshake metadata. The authors of (Busch et al. 2021) highlight that most network-based classification methods concentrate on traffic between two endpoints, with granularity ranging from transaction-level events to aggregated conversations. These resolution levels become important when aiming to distinguish subtle malicious signals from background activity. An important motivation for this research lies in the persistence of command-and-control (C&C) frameworks that adapt easily to encrypted channels. Botnet operators commonly disguise control messages inside legitimate-looking HTTPS sessions or QUIC connections, rendering conventional intrusion detection ineffective unless payloads are exposed, which is infeasible here due to privacy constraints. Experimental evidence supports the feasibility of flow-based detection: multi-phase systems such as MalPhase denoise aggregated flows and then apply staged classification to advance from binary malicious/benign discrimination toward type and family identification. Unlike packet-level inspection tools such as BotHunter or BotFinder, which depend on identifiable state sequences or protocol-specific features (Piskozub et al. 2021), this thesis adopts an entirely protocol-agnostic stance at the payload level. Another driver of interest in this domain stems from changes in TLS 1.3 session establishment. These alterations obscure formerly accessible fields such as certificate details during handshake; thus analysts must rely on features not removed by encryption, including

encrypted payload statistical markers or certain observable timing sequences (Gomez et al. 2022). This makes the role of careful feature engineering central to enhancing classifier performance while avoiding prohibited deep inspection techniques. Furthermore, evaluation methodologies must respect variability in real-world conditions without compromising reproducibility. Controlled datasets created through browser automation, such as automated playback of video over QUIC connections with Puppeteer, provide reference baselines for benign encrypted flows under known conditions (Zhang and Su 2023). Balancing such curated benign sets with diverse malicious traffic obtained via sandbox execution allows testing classifiers under realistic noise ratios representative of operational environments where malicious signals mix with high volumes of normal use. One aspect often understated is the heterogeneity across malware families and operational tempos. For instance, bursts of botnet messaging create short-lived yet intense deviations within flow metrics; conversely, slow exfiltration campaigns blend persistently into ordinary traffic patterns (Piskozub et al. 2021). A system's ability to adapt its analysis without overfitting to specific background datasets determines broader applicability. Critically, manual labeling of malware families for validation, as performed by selecting samples from common and rare variants using AVClass guidance, ensures diversity in training while filtering out irrelevant benign flows.

Ethical considerations also shape the motivation behind this research. The proposed methodology maintains user confidentiality by restricting itself entirely to observable metadata already accessible for routing purposes, sidestepping any exposure of personal or sensitive content (Gomez et al. 2022). Such compliance with privacy expectations aligns this approach not merely with technical effectiveness but also with legal and societal standards around data protection. From a scientific standpoint, there is merit in comparing models like Naive Bayes, Random Forest, and Gradient Boosting under identical feature sets. These classical algorithms provide interpretability advantages over more opaque deep neural network models while still offering competitive accuracy depending on feature discriminability and noise handling (Shah, Ahmed, and Nagaraja 2022a). At the same time, integration of feature selection with noise filtering modules, as in multi-tier architectures, may reveal which statistical traits hold predictive value across varied encryption protocols. In fact, it appears that mixing richer contextual metadata with baseline flow statistics could lessen false positives; some approaches augment internal metrics with external indicators such as reputation scores when available, though reliance on these can be risky if such auxiliary data is incomplete or inaccessible (Ferreira et al. 2021). Certain studies have explored incorporating trusted external intelligence directly into flow-level classification pipelines by linking observations with reputation databases; while this can sharpen detection boundaries under constrained scenarios, its practicality diminishes when said external sources are unavailable or outdated (Christenson et al. 2024). This dependency may introduce fragility into operational deployments if reputation feeds fail or are delayed; Disclosure demonstrated an augmentation strategy using reputation scores alongside flow-derived features, which kept false positives low but assumed consistent access to these external datasets, a condition unlikely in all environments (Lee et al. 2023). Recent work suggests that rules derived from estimating higher-level object transactions, such as inferred HTTP request-response pairs or connection-level QUIC metrics, from encrypted packet sequences may enrich feature

spaces without violating content confidentiality requirements (Favole et al. 2021). Such inferred attributes could serve as intermediate layers between raw per-packet statistics and application-level labels, providing classifiers a structured context they would otherwise lack.

The overall motivation thus synthesizes technical necessity, the inability to deploy payload-dependent detectors, with methodological opportunity afforded by machine learning on flow-derived features. By addressing encrypted traffic threats through statistical pattern recognition rather than content analysis, this research aims to fill a measurable gap between purely signature-based approaches struggling against encryption and intrusive decryption-heavy solutions incompatible with privacy-respecting operation.

Chapter 2

Background and Fundamentals

2.1 Encrypted Network Traffic

2.1.1 Definition and Characteristics

Encrypted network traffic in modern communication systems refers to data transmissions where the payload and, in many cases, protocol metadata are protected through cryptographic mechanisms. Protocols such as TLS 1.3 and QUIC go beyond simply encrypting content; they obscure handshake details, certificate information, and elements of the session setup that were previously visible for inspection (Gomez et al. 2022). This encryption serves to ensure confidentiality and integrity but also limits the observable attributes for security monitoring. The encrypted streams typically use Authenticated Encryption with Associated Data (AEAD) to bind payload integrity with confidentiality guarantees, employing nonces derived from packet numbers to safeguard message sequences from tampering (Fischlin, Günther, and Janson 2024). QUIC, for example, transmits only partial packet numbers alongside ciphertext, requiring receivers to reconstruct complete numbers within a dynamically sized sliding window. This design choice affects how temporal sequencing is inferred from encrypted flows and impacts analytical models relying on timing or order-of-arrival metrics. A defining characteristic of TLS 1.3 and QUIC flows is that while payload contents are inaccessible without private keys, certain statistical and structural properties remain observable at the network level. Among these are flow duration, total byte counts, inter-packet timing patterns, record lengths, and directional sequence markers in TCP or UDP segments (Shah, Ahmed, and Nagaraja 2022a). These features originate from the unavoidable operational behavior of protocols when transmitting data, encryption changes what is hidden but cannot mask every attribute of traffic exchange. Such side-channel features become primary candidates for analysis when searching for anomalies indicative of malicious activity. Unlike earlier versions such as DTLS 1.2 or TLS 1.2 where full packet numbers might be transmitted in clear text, TLS 1.3 adopts measures that suppress protocol-specific identifiers during its handshake and record phases. This obscuration reduces the risk of targeted interception but simultaneously shifts detection strategies toward modeling overall flow patterns rather than relying on explicit header values. The characteristics here include high variability in session format depending on negotiated extensions and ciphersuites, as well as differences

in packet-size distributions shaped by both application-layer fragmentation strategies and lower-level transport behaviors. From an architectural perspective, QUIC integrates transport capabilities directly within its encrypted environment over UDP. This creates multiplexed streams where meta-information like connection identifiers or encryption key transitions are managed internally rather than exposed at network edges (Fischlin, Günther, and Janson 2024). As a consequence, common classification approaches that treat each bidirectional communication pair individually must adapt, capturing relationships among multiple simultaneous flows can yield improved detection fidelity compared to analyzing isolated transmission sequences (Busch et al. 2021). The threat landscape surrounding encrypted traffic is broad. Adversaries exploit its confidentiality guarantees to conceal coordinated actions such as distributed denial-of-service (DDoS), ransomware staging operations, or botnet command-and-control messaging (Khaleel et al. 2024). These actions can manifest subtly within flow metrics: for instance, repeated connections over short intervals with consistent payload sizes may allude to automated control messages; conversely, long-duration low-throughput flows might carry exfiltrated data spread across hours to evade threshold-based alarms. Dataset-driven assessments illustrate this variability, collections like CICDDoS2019 encapsulate diverse attack morphologies across timestamps, addresses, protocols, and embedded labels capturing attack categories (S and Padmavathi 2024). In controlled experimental conditions using emulation frameworks or sandbox datasets containing suspicious executions, researchers find that even fully encrypted TLS flows exhibit family-specific statistical fingerprints when aggregated over time (Gomez et al. 2022). Clustering approaches reveal recurring structures in malfeasant sessions without depending on decrypted payloads or manual family labelling. These discovered characteristics coexist with normal application traffic patterns, for example browser-mediated QUIC video streams differ markedly in duration variance and byte bursts compared to malware-generated QUIC channels engineered for persistent low-visibility communication. However, these definitional traits are not static; protocol specifications evolve with security considerations in mind. Observations regarding DTLS 1.3's susceptibility to multiple forgery attempts have prompted working groups to introduce explicit limits on packet protection forgery tolerance (Fischlin, Günther, and Janson 2024). Such adaptations shift potential indicators available for external observation by altering the operational envelope within which encrypted communications occur. Examining these characteristics thus requires distinguishing between inherent protocol behaviors mandated by standards and incidental traits emerging from particular implementations or usage contexts. Features like aggregate throughput per unit time result from both application demands and network conditions; deciphering whether deviations betray malicious intent involves interpreting them against expected baselines gleaned from legitimate traffic datasets. From this perspective, the definition of encrypted network traffic encompasses not merely any transmission safeguarded through ciphers but specifically those sessions where observational capability is restricted to externally visible metadata plus minimal unencrypted headers essential for routing. Characteristics include protocol-specific handling of sequence identifiers (full vs truncated packet numbers), negotiated encryption schemes influencing frame structure, persistence patterns determined by application logic driving the transport layer's utilization profile, and any detectable fluctuations rooted in timing between sending

units dictated by control-command scheduling (Shah, Ahmed, and Nagaraja 2022a). Ultimately these definitional markers frame both the constraints imposed upon analysts, restricted visibility into contents, and the opportunities afforded by residual statistical signals left unshielded by encryption processes. This dual nature shapes research methodologies into detecting threats without compromising privacy guarantees intrinsic to modern secure communication environments.

2.1.2 Challenges in Traffic Analysis

Analyzing encrypted traffic without direct access to packet payloads presents several intertwined challenges that go beyond the mere lack of content visibility. The most immediate difficulty stems from how encryption protocols such as TLS 1.3 and QUIC reduce observable metadata traditionally used for inference. In these environments, handshake details, cipher suite selections, and certificate exchanges are either entirely hidden or severely truncated, which dismantles earlier strategies relying on explicit protocol fields for classification (Nawrocki et al. 2022). What remains for analysis are flow-level attributes such as packet counts, interarrival times, directionality ratios, and session durations. These features can be noisy due to heterogeneous network conditions, varying application behaviors, or middlebox interference. Noise itself becomes a critical obstacle. In many operational datasets, malicious flows coexist with large proportions of benign traffic exhibiting overlapping statistical properties. This is particularly problematic in non-burst malicious flows where temporal and volumetric patterns resemble background activity. Lower-tier classification modules operating on shorter observation windows may react faster to transient anomalies but at the cost of higher false positives when noise dominates the signal. Higher-tier modules achieve more resilience by aggregating over longer time spans yet risk missing short-lived threats (Piskozub et al. 2021). Such trade-offs between detection latency and precision force a careful balancing of tier-specific parameters in multi-phase systems. An additional technical hurdle lies in differentiating benign services from malicious exploitation when both share common encrypted transports. Experiments with tools like Joy illustrate that if a model overly associates certain contextual environments (e.g., sandbox TLS 1.0 traffic) with maliciousness during training, it will misclassify normal flows under similar conditions unless retrained with explicit benign examples drawn from those contexts (Gomez et al. 2022). Correcting such bias improves precision but often increases false negatives as the classifier relaxes its decision boundaries. This interplay suggests that maintaining high accuracy cannot rely solely on class imbalance corrections; feature selection strategies must actively seek discriminators minimally affected by deployment context. Protocol-specific mechanics pose further complications in measurement fidelity. For example, QUIC's handling of multiple concurrent streams within a single connection, each potentially carrying independent transactions, generates multiplexing behaviors that blur simple request-response mapping (Zhang and Su 2023). Inferring individual operation boundaries over QUIC requires deducing start and end points from packet timing, size distributions, and directional shifts inside aggregated streams. Multiplexed traffic may conceal irregularities in one stream beneath bulk legitimate data in another, decreasing anomaly detection sensitivity. High-performance en-

vironments introduce resource constraints into the equation. Even when classifiers demonstrate strong performance with full attribute sets, for instance reaching over $96\,\%$ accuracy for certain QUIC flow categorizations, real-time deployments handling gigabit-per-second rates might favor reduced feature sets to lower computational overhead (Wang, Lyu, and Sivaraman 2024). While discarding low-information features can preserve throughput capabilities, it risks removing subtle indicators important for rare but severe attack types. Another layer of challenge emerges from adversarial manipulation targeting machine learning models themselves (Khaleel et al. 2024). Attackers can craft traffic patterns specifically to mislead anomaly detectors, for example by padding malicious sessions with synthetic benign-like sequences, or exploit model biases learned from unbalanced training corpuses. As encryption inherently masks payload content, adversaries gain greater control over shaping visible metadata without exposing alterations to intermediate inspection points. Graph-based formalisms face analogous issues; while they capture entity-to-entity relationships more holistically than isolated flow metrics, graph sparsity or sudden density changes under variable load can produce ambiguous signals requiring context-driven interpretation (Fu, Li, and Xu 2023). Sparse graphs in off-peak hours may resemble graphs pruned due to throttled botnet communications; conversely dense legitimate usage surges could mimic distributed scanning behavior depending on node and edge aggregation criteria. Temporal stability also complicates robust detection since legitimate software updates or content delivery optimizations lead to gradual drifts in baseline statistics for encrypted protocols. If not retrained periodically on refreshed benign datasets, ideally capturing both controlled experiments and live network variations, models risk accruing anachronistic assumptions decreasing their adaptability. This phenomenon interacts with operational necessities like connection ant amplification limits in QUIC that alter packet sizing strategies (Nawrocki et al. 2022), thereby modifying side-channel attributes used by classifiers. Operational reconstruction offers yet another dimension of difficulty: inferring specific activities from encrypted industrial robot communications demands distinguishing genuine operational delays from induced jitter or congestion effects unrelated to workflow type (Shah, Ahmed, and Nagaraja 2022b). Here machine learning must deal with labeling scarcity because ground truth for such flows is expensive to obtain outside carefully simulated scenarios. Finally, ethical and legal constraints cap the range of observable features analysts can legitimately collect from production networks. To adhere strictly to privacy preservation mandates means abstaining entirely from payload inspection or SSL/TLS key extraction even when technically feasible, which removes potentially clarifying indicators available under less restrictive regimes. This preservation reinforces dependence on statistical markers derived externally accessible metadata alone (F. Ullah, Srivastava, and S. Ullah 2022), intensifying reliance on rigorous preprocessing pipelines that filter irrelevant feature noise without discarding indicators vital for rare event detection.

A further complication comes from low-level protocol integrity gaps that offer adversaries leeway to manipulate early handshake packets or transport headers without being detected by higher-layer security guarantees (Chen et al. 2021). Such vulnerabilities may not directly expose application data yet can subtly degrade availability or bias classifier training data toward skewed patterns, amplifying several of the challenges outlined above.

In practice, the pressure to sustain accurate classification while processing encrypted traffic at scale has prompted selective use of attributes based on their computational cost and predictive value, especially when hardware resources restrict real-time analysis across all possible features (Lande, Feher, and Strashnoy n.d.). Deciding which features can be trimmed without eroding classifier reliability remains context-dependent and is shaped by both protocol characteristics and operational constraints affecting deployment viability. Collectively these challenges portray a landscape where malicious activity detection within encrypted traffic depends critically on balancing scope reduction imposed by privacy respect against expanded methodological sophistication in feature engineering and model adaptation. The lack of payload visibility forces innovation along dimensions such as denoising autoencoder training procedures (Piskozub et al. 2021), sandbox-informed labeling corrections (Gomez et al. 2022), and adaptive tier architectures, each meant to counteract distinct obstacles yet interdependent in practical deployments that span diverse protocol contexts and performance constraints highlighted previously in Section 2.1.1.

2.2 TLS 1.3 and QUIC Protocols

2.2.1 Protocol Overview

TLS 1.3 and QUIC are modern cryptographic protocols that govern secure communications over IP networks, each embodying a set of design choices that influence both their security properties and the residual metadata available for traffic analysis. TLS 1.3, standardized to replace earlier TLS iterations, aims to reduce handshake latency and increase privacy by encrypting more of the negotiation process, including parts of the handshake that previously were in cleartext such as certificates and certain extensions. It operates atop TCP, providing session-based encryption with mutual authentication possibilities depending on deployed configurations (Gomez et al. 2022). The encryption format generally follows an AEAD construction where associated data bind integrity checks to header information, while payloads are encrypted with symmetric keys derived from the initial handshake process. QUIC builds on concepts found in TLS 1.3 but integrates encryption and transport into a single protocol over UDP. All QUIC sessions carry TLS 1.3 handshake semantics within QUIC frames, meaning application data streams and transport control information are encrypted together once session keys are established. Packet headers expose only minimal necessities for routing, connection IDs and partial packet numbers, while the sequence reconstruction relies on a sliding window maintained at each endpoint (Fischlin, Günther, and Janson 2024). This mechanism allows endpoints to derive full packet numbers from truncated versions by evaluating them relative to the moving window range. Such truncation minimizes header size but complicates passive traffic analysis since timestamp-order inference becomes indirect and dependent on observed arrival sequences rather than explicit numbering. One consequence of these architectures is that traditional field-based fingerprinting approaches lose access to most handshake parameters unless active probing or endpoint cooperation occurs, neither of which fits within privacy-preserving monitoring constraints.

For TLS 1.3 over TCP, observable metadata consist largely of packet length distribu-

Table 2.1: Passive visibility comparison: TLS 1.2 vs TLS 1.3 vs QUIC (TLS 1.3 over UDP).

Phase / Item	TLS 1.2	TLS 1.3	QUIC (TLS 1.3)
Client initiation	ClientHello visible (e.g., SNI, extensions)	ClientHello mostly visible*	UDP header visible; QUIC long-header fields (type/version/DCID/SCID) visible
Server response	ServerHello visible	ServerHello visible	Minimal QUIC header fields visible; remainder protected after keys
Certificate	Visible	Encrypted	Carried in QUIC CRYPTO frames; encrypted (after keys)
Handshake remainder	Largely visible metadata	EncryptedExtensions / CertificateVerify / Finished encrypted	TLS 1.3 handshake runs inside QUIC; protected within encrypted frames
Application data	Encrypted	Encrypted	Encrypted; QUIC additionally applies header protection (e.g., packet number protection)

*ClientHello fields such as SNI may be encrypted if ECH is deployed.

tions during and after the handshake, timing intervals between records, and byte counts per direction across a session's lifespan (Gomez et al. 2022). In QUIC, additional complexity comes from its multiplexed stream capabilities: multiple independent logical streams can be opened concurrently inside one connection context without exposing stream identifiers outside the encrypted payload space (Zhang and Su 2023). This multiplexing allows legitimate high-throughput services like video or file transfer to share UDP ports with latency-sensitive control channels, an adversary could exploit this feature to hide intermittent malicious communications among benign bulk transfers without altering visible transport-layer markers. The nonce generation strategy in QUIC's packet protection stage also reflects protocol integration with cryptographic measures. Nonces for AEAD encryption derive from an XOR between a static initialization vector (IV) fixed at channel start and padded packet numbers (Fischlin, Günther, and Janson 2024). The encoded packet number length can vary ($8\,\mathrm{bit}$, $16\,\mathrm{bit}$, $24\,\mathrm{bit}$, or $32\,\mathrm{bit}$) depending on negotiated parameters or channel state, impacting external visibility into sequence patterns. Because AEAD binds header protection and payload confidentiality together, passive observers cannot deduce application-layer events except through indirect correlations in statistical features such as bursts in packet size or shifts in interpacket gaps linked to possible application transitions. From a performance standpoint, QUIC leverages reduced handshake round trips compared to TLS over TCP by including cryptographic setup data in its initial packets once certain conditions are met; however, field measurements indicate that optimized handshakes remain rare in deployed infrastructures (Nawrocki et al. 2022). Retry mechanisms and 1-RTT handshakes occur infrequently, limiting how often clients experience latency benefits envisioned by the

protocol designers. For monitoring systems this means fewer instances where abbreviated negotiation patterns might serve as indicators; most connections still present longer setups resembling full handshakes even if they hide content details behind encryption envelopes. The interaction between protocol features and detection strategies becomes apparent when inspecting comparative detection designs (Fu, Li, and Xu 2023). Observable elements of TLS 1.3 flows center on generic statistical attributes, flow durations, total transferred bytes, per-packet sizing, even though protocol headers themselves offer limited classification utility due to their confidentiality guarantees. Likewise, in QUIC flows these aggregate statistics alongside inferred concurrency from multiplexing become critical inputs for behavior modeling algorithms. The challenge lies in distinguishing whether anomalies result inherently from protocol-internal operations (e.g., congestion window adjustments altering burst characteristics) or from exogenous factors tied to malicious intent (e.g., repeated microbursts signaling automated command polling). Some proposed enhancements consider combining TLS-specific indicators with broader network behaviors such as client/server role identification or interaction graph structures among communicating entities (Gomez et al. 2022). While payload parsing remains off-limits under strict privacy mandates, metadata like certificate presence during handshakes, when unencrypted, or Server Name Indication values can contribute useful signals in contexts where they are exposed (e.g., older protocol fallbacks or misconfigurations). These should be weighed against likelihood of availability; modern deployments frequently suppress them entirely via encryption before network transit. Similarly for QUIC connections targeting streaming services: operators have developed classification processes leveraging flow feature construction across UDP-based encrypted video traffic without decrypting any frame data (Wang, Lyu, and Sivaraman 2024). By aggregating measurements at device-type or software-agent granularity rather than per-flow alone, these methods achieve elevated classification accuracy even amid obfuscation through encryption layers. In practical deployment scenarios focusing strictly on externally visible metrics, as mandated here, the overview underscores that both protocols strive to minimize exploitable side channels while retaining unavoidable operational footprints at flow level. Residual features thus stem largely from transport-layer behaviors inherent to delivering encrypted application payloads: timings shaped by acknowledgement strategies; byte volumes formed by segmentation logic; connection lifetimes dictated by service requirements; and multiplexing footprints guided by concurrent transaction management inside secured sessions. Crafting detection models against this backdrop requires careful calibration so that protocol-native peculiarities do not inject confounding variances into threat classification baselines established through prior benign traffic observation datasets (Author n.d.).

2.2.2 Security Features and Limitations

TLS 1.3 and QUIC incorporate layered security mechanisms that are intended to reduce the attack surface of network communications while ensuring confidentiality and integrity. Their designs remove or conceal metadata that earlier protocol versions exposed to potential exploitation, but these same design choices constrain what can be derived by passive traffic analysis. TLS 1.3 enforces authenticated encryption with associated data (AEAD) as its only

cipher category, limiting options to algorithms such as AES_128_GCM, AES_256_GCM, AES_128_CCM, and CHACHA20_POLY1305 (Kempf et al. 2024). AEAD encrypts the payload and simultaneously protects the header metadata, ensuring attacks involving partial tampering become infeasible without also breaking confidentiality. By pruning non-AEAD ciphers entirely, the protocol avoids legacy weaknesses linked to outdated cryptographic constructs. The handshake phase of TLS 1.3 encrypts much of the negotiation process, most notably certificates, preventing third parties from extracting these identifiers during session setup (Gomez et al. 2022). While this heightens privacy protection against passive adversaries, it shifts detection methodology away from field-based inspection toward statistical behavior modeling. QUIC adopts these handshake semantics but integrates them into its transport layer over UDP, encapsulating both application-layer payloads and transport control information in a unified encrypted envelope (Zhang and Su 2023). Packet headers in QUIC do not expose full sequence numbers; instead they transmit truncated versions whose reconstruction requires endpoint-maintained sliding windows (Kempf et al. 2024). This choice reduces packet overhead and minimizes identifiable markers but adds complexity to efforts attempting to infer exact event ordering without endpoint involvement. From an operational perspective, these protocols impose constraints on performance-related offloading functions available in hardware. TCP benefits more directly from segmentation offloads at network interface controllers (NICs), whereas QUIC performs packetization within user space, limiting potential acceleration unless implementations adapt to support cryptographic or segmentation offload (Jaeger et al. 2023). While this architectural nuance does not inherently weaken security guarantees, it influences real-time monitoring designs where packet throughput interacts with metadata extraction strategies. If a monitoring system processes packets inline, less offloading may increase processing latency for QUIC flows compared to similarly secured TCP sessions. One notable security enhancement lies in how QUIC generates nonces for AEAD encryption, an XOR operation between a static initialization vector established per connection and padded packet numbers (Kempf et al. 2024). This scheme ensures uniqueness across sessions while tying protection closely to transport sequence handling. However, by integrating encryption so tightly with sequencing logic, it eliminates straightforward mapping between observable packet counts and actual application-level transactions for passive observers. QUIC further limits retry opportunities and minimizes 0-RTT usage when conditions are suboptimal; although intended for performance improvement under certain networks, limited occurrence in real deployments means analysts rarely observe those minimal handshake patterns that could theoretically serve as side-channel discriminators (Nawrocki et al. 2022). Both TLS 1.3 and QUIC protect against specific exploits such as downgrade attacks or cipher suite probing through enforced cipher list pruning and strict key exchange rules (Kempf et al. 2024). Yet there remain limitations: internal vulnerabilities in implementation code could undermine intended protections even when protocol-level specifications are met. For instance, poorly handled certificate validation routines or insecure random number generation might allow adversaries to mount successful man-in-the-middle attacks despite protocol compliance. In mobile environments particularly, misconfigured SSL/TLS stacks have been documented as enabling MITM interception within encrypted channels when developers fail to correctly implement verification steps, issues in-

dependent of the protocol's inherent design yet impactful on security outcomes (Cibalik and Kocak 2021). In analytical terms relevant to detection systems constrained from decrypting payloads, these strong protections narrow feature availability severely. Observable fields such as Server Name Indication may be missing entirely when encryption covers early handshake messages; destination IP addresses may change dynamically due to content delivery architectures or be hidden behind aggregation mechanisms like load balancers or anycast routing. In clustering experiments over TLS 1.3 traffic lacking SNI headers yet targeting identical IP ranges, flows grouped correctly based on encrypted-payload differences without incorporating IP features (Gomez et al. 2022), indicating potential avenues for behavior-based grouping despite limited plaintext cues. Another limitation arises from susceptibility to adversarial evasion techniques crafted against machine learning models trained on such reduced feature sets. By manipulating byte counts per record or adjusting payload lengths within plausible bounds allowed by AEAD framing rules, an attacker can craft sessions that bypass anomaly detectors calibrated on more typical encrypted traffic profiles (Xavier, Novo, and Morla 2022). Experiments modifying Metasploit command-and-control TLS flows achieved high evasion rates against retrained detectors until payload-side changes lowered success probability, but still proved such adaptive strategies viable given continued reliance on observable statistical markers alone. Furthermore, while protocols are structurally immune to many passive analysis attacks due to their concealment measures, they cannot inherently prevent abuse scenarios where encryption serves illegitimate purposes, for example hiding malware infrastructure within persistent QUIC channels using steady low-amplitude byte bursts indistinguishable from benign IoT telemetry streams without supplementary context or correlation analysis (Khaleel et al. 2024). Addressing such misuse depends not solely on protocol features but on broader defensive frameworks capable of correlating flow-level signals across different vantage points. In summary from a scientific stance, TLS 1.3 and QUIC implement strong cryptographic scaffolding that achieves their primary goals of securing communications against unauthorized inspection and tampering (Kempf et al. 2024). However these same measures limit visibility into potentially malicious activities conducted over them when payload decryption is prohibited; they push analytical methodologies toward indirect inference via side-channel attributes that may be noisy or deliberately obfuscated by adversaries (Xavier, Novo, and Morla 2022). Limitations thus emerge not from deficiencies in the applied cryptography itself but from tensions between effective privacy-preserving design and defenders' need for actionable indicators at the network level, a balance that shapes both protocol evolution and monitoring strategy development going forward from Section 2.2.1.

2.3 Flow-Level Analysis

Flow-level analysis in the context of encrypted traffic shifts attention away from packet payload contents and toward aggregated characteristics derived from communication sequences between endpoints. This approach treats each flow as a fundamental observational unit, where a flow is typically defined by a tuple consisting of source and destination network addresses, transport protocol, and temporal boundaries marking the start and

end of continuous data exchange. In high-security scenarios where TLS 1.3 or QUIC encrypt headers beyond routing data, only metadata unavoidable for delivery remains visible. Researchers exploit this residual metadata to construct statistical feature sets suitable for detection tasks without breaching confidentiality constraints (F. Ullah, Srivastava, and S. Ullah 2022). The granularity at which flows are analyzed can vary. Some methodologies group packets into bi-directional conversations representing complete transactions between client and server, while others apply more compact observation windows to detect shorter events embedded within longer flows. Window size directly affects responsiveness and false positive rates: smaller windows may identify abrupt anomalies faster but increase susceptibility to transient benign fluctuations; longer windows smooth out noise yet risk missing ephemeral threats. Multi-tier architectures attempt to balance these trade-offs by processing aggregated flows through successive classification phases. For instance, initial stages may filter flows suspected of carrying malicious activity using coarse indicators such as unusual byte-per-packet ratios, followed by deeper statistical modeling in later phases to determine the specific threat family involved (Piskozub et al. 2021). Classification models applied at the flow level rely heavily on selected features that remain observable despite encryption. These frequently include overall flow duration, total byte counts per direction, packet count distributions, inter-arrival times, record size statistics for TLS streams or frame lengths in QUIC, and directional asymmetries indicative of client/server roles (Gomez et al. 2022). Importantly, given that multiple networked applications often produce overlapping ranges for these features, especially when they use similar infrastructure like CDNs, the challenge lies in selecting attributes minimally correlated with benign multiplexed services (Taylor et al. 2017). Graph-based formalisms enhance analysis by treating flows not simply as independent records but as edges within a broader communication map derived over monitored time frames. Nodes correspond to endpoints and edges aggregate the flow attributes between them; such constructs reveal patterns like repeated interactions across disparate endpoints or sudden increases in connection density possibly associated with scanning or botnet coordination. One noteworthy strategy is constructing network flow graphs from cumulative observations and then feeding these into graph neural networks (GNNs) capable of learning structural as well as statistical properties. Instead of evaluating isolated sequences, GNN-based approaches can capture relationships among multiple entities active concurrently, critical for detecting malicious clusters concealed amongst normal traffic. In practice, implementing such methods entails aggregating feature vectors describing individual flows (e.g., byte counts, timing entries) along edges between any two communicating nodes within a specified interval. Parallel flows are aggregated to reflect overall interaction intensity rather than isolated transmissions (Busch et al. 2021). The complexity increases further under noisy conditions where benign traffic mixes naturally with malicious signals inside single flows. Experiments simulating noisy datasets, where malware-generated flows contain deliberately inserted benign-like segments, illustrate how classification accuracy deteriorates if models train exclusively on clean samples without representation of such hybrid cases. Evaluating performance under varying ratios of benign-to-malicious content offers insight into system resilience; MalPhase tests demonstrated that increasing the benign content proportion obscures identifying traits unless multi-phase classifiers integrate denoising

mechanisms before final classification passes (Piskozub et al. 2021).

Table 2.2: Flow-level feature categories for encrypted traffic analysis.

Category	Typical features (examples)	Detection intuition
Timing	flow duration; mean/variance inter-arrival time; jitter	periodic polling, automation, latency patterns
Size	total bytes; packets per flow; mean/median packet size; size variance	bulk transfer vs control-like traffic; shape of traffic
Directionality / asymmetry	bytes out/in ratio; packets out/in ratio; client/server dominance	exfiltration (high outbound); request/response imbalance
Burst metrics	burst length; burst rate; idle time between bursts	interactive vs scripted behavior; micro-bursts in C&C
Window-based segmentation	features computed per sliding/fixed window	early detection; handles long flows with phase changes
Graph features	degree/centrality; community structure; edge persistence	coordination, bot clusters, shared infrastructure

Within IoT environments using protocols like MQTT over TCP or QUIC-style UDP encapsulation, flow-level analysis faces additional complexity due to device heterogeneity and continuous telemetry generation patterns. IoT deployments contribute vast quantities of short-duration low-throughput flows whose variability aligns loosely with certain stealthy exfiltration techniques employed by adversaries. Ensemble machine learning frameworks evaluated against diverse IoT anomaly detection datasets further confirm that combining decision outputs from multiple model types often yields higher detection stability compared to relying on a single classifier trained over all observed conditions (Lai et al. 2024). An important consideration when extracting flow-level features under these constraints is avoiding reliance on volatile identifiers such as IP addresses or DNS queries that can change across sessions due to operational factors unrelated to maliciousness (Taylor et al. 2017). Content delivery strategies employing DNS caching mean certain queries might never be observable externally; load-balancing mechanisms cause destination IP variations even for consistent application sessions. Protocol encryption trends further reduce utility from TCP payload features since most modern applications encrypt them entirely via SSL/TLS pipelines. Consequently analysts must design feature sets biased toward persistent operational markers such as inter-packet timing distributions or sustained directionality imbalances rather than ephemeral identifiers. While classical supervised learning algorithms like Random Forests or Gradient Boosting can classify based on engineered statistical features with high accuracy in controlled datasets (F. Ullah, Srivastava, and S. Ullah 2022), unsupervised clustering techniques also hold promise where labeled malicious samples are rare or incomplete. Clustering operates on similarity groupings derived from extracted feature spaces; anomalous clusters deviating from baseline benign activity patterns can then be targeted for further inspection or active investigation via sandboxing tools. Hybrid solutions combining binary supervised detectors with unsupervised grouping modules have demonstrated improved adaptability against unseen malware families without requiring prior inclusion in training corpuses, a valuable trait in rapidly shifting threat landscapes exemplified by daily-emerging variants noted during MalPhase evaluations (Piskozub et al. 2021). Ultimately

flow-level analysis operates at the intersection of constrained observability and behavioral inference. Where protocols like TLS 1.3 and QUIC purposely suppress handshake visibility and truncate identifiers for privacy protection (Fischlin, Günther, and Janson 2024), analysts substitute content-rich inspection with multidimensional modeling drawn entirely from externally measurable flow properties. This substitution demands precise preprocessing pipelines capable of filtering ambient noise while preserving subtle long-tail signals indicative of irregular coordination or covert transfers embedded within encrypted connections, signals potentially masked inside multiplexed legitimate streams yet recoverable through careful graph aggregation and tiered classification approaches building on strategies outlined earlier in Section 2.2.2.

Chapter 3

Threat Model and Encrypted Threat Landscape

3.1 Types of Malicious Activities

Table 3.1: Threat types and expected flow-level metadata signals in encrypted TLS 1.3 / QUIC traffic.

Threat type	Typical flow-level signals	Common interpretation
Command-and-Control (C&C)	short flows; periodic reconnections; similar packet/byte sizes; repeated destination(s)	automated beaconing/polling; controller communication patterns
Data exfiltration	long-duration flows; outbound-heavy bytes; low/steady rate; persistent sessions	covert upload of stolen data; throttled transfer to avoid thresholds
DDoS (if applicable)	high flow rate; many short flows; bursty traffic; many sources to one target	volumetric flooding; coordinated distributed attack behavior

3.1.1 Command-and-Control Communications

Command-and-control (C&C) infrastructures facilitate remote orchestration of compromised endpoints by adversaries, enabling them to issue instructions, update malware configurations, and exfiltrate harvested data without requiring direct interaction. Operationally, these communications often exhibit design choices intended to conceal their presence in ordinary network activity. When embedded within fully encrypted protocols such as TLS 1.3 or QUIC, payload inspection becomes infeasible under privacy-preserving assumptions stated earlier, necessitating inference from flow-level attributes alone. In such contexts, statistical deviations in flow duration, byte volumes per direction, and packet inter-arrival distributions become primary indicators of covert orchestration channels (Piskozub et al. 2021). A recurrent trait of C&C traffic is its rhythmic or patterned recurrence; connections may occur at fixed intervals dictated by the bot's polling cycle. These scheduled sessions can be brief yet frequent, generating clusters of short-duration flows between a set of compromised hosts and designated servers. Even when multiplexed inside larger legitimate streams, as can happen with QUIC, such periodicity may appear in the temporal graph structure linking endpoints over monitoring intervals (Busch et al. 2021). Graph aggregation methods

are well-suited to capture this phenomenon: by mapping flows as edges between nodes and overlaying time-series metrics on edge activity, unusual regularity or node centrality spikes hint at orchestrating roles within observed traffic. The high density around certain nodes under otherwise sparse conditions could indicate single entities directing multiple bots across diverse network segments. Because the adversary controls observable metadata linked strictly to transport-layer behavior within encrypted envelopes, it is possible for them to blend C&C messages with benign features strategically. Noise injection experiments have demonstrated that embedding segments imitating benign flow characteristics, whether in byte-size distribution or timing variance, reduces classifier recall for type and family categorization unless denoising modules pre-process data (Piskozub et al. 2021). This adaptability compels analysts to consider features resilient to manipulation; aggregate asymmetry between ingress and egress volumes over sequences of related flows remains less prone to mimicry compared to single-flow metrics. For TLS 1.3-based C&C sessions, suppression of handshake certificate visibility removes straightforward server attribution opportunities (Gomez et al. 2022). This lack forces reliance on less volatile identifiers, such as persistence of destination IP-block usage over time or consistency in session timeout policies across seemingly unrelated client IPs connecting to the same range. In scenarios where Server Name Indication (SNI) values emerge due to misconfiguration or protocol fallback, they can act as supplemental identifiers, though modern deployments frequently encrypt early handshake data in adherence to specification guidelines. Consequently the observational strategy shifts toward clustering flows into behavioral families not by endpoint denomination but by shared statistical footprint. QUIC introduces added complexity: it allows parallel streams within a single UDP connection carrying different logical channels unseen outside the encryption boundary (Zhang and Su 2023). An adversary might exploit this by embedding control messages into low-bandwidth streams concurrent with high-throughput activities (e.g., media transfer). Detecting C&C in such environments involves inferring stream concurrency indirectly from packet-size transitions and burst timing patterns usually tied to changes in active stream composition. Sudden appearance of recurring microbursts amidst otherwise continuous large-packet transfers could suggest hidden low-volume exchanges fitting C&C profiles. The practical detection architecture therefore benefits from incorporating multi-tier classification. An initial coarse filter targeting anomalous flow-duration distributions and sustained connection repetition can flag candidates for finer-grained statistical analysis (Piskozub et al. 2021); subsequent passes might integrate graph-based centrality measures or persistence scoring relative to background baselines (Busch et al. 2021). Such staged systems mitigate false positives arising from one-off irregularities in benign services while building confidence around persistent anomalies. Given that malware operators often employ domain generation algorithms (DGAs) or IP rotation for their controllers, relying purely on identifier continuity is ineffective without correlation across multiple sessions' feature vectors. A promising tactic involves mapping higher-order relationships among destination prefixes observed over extended periods. When certain prefixes consistently exhibit interaction patterns atypical for their apparent service category, such as low-byte periodic exchanges rather than expected bulk transfers, these may indicate C&C aggregation points independent from transient DNS names. In IoT-oriented attack

scenarios, telemetry-style C&C merges seamlessly with native device chatter; here device heterogeneity exacerbates baseline modeling difficulties (Lai et al. 2024). Flow datasets aggregating traffic for healthcare sensors or smart appliances reveal wide diversity in normal behavior profiles; nonetheless C&C traffic tends toward simpler command-response models with constrained variability across sessions relative to human-driven usage patterns. Leveraging transfer learning models trained across varied device types could allow anomaly detectors to spot deviations even when individual device baselines are poorly characterized at deployment time. Resilience against adaptive evasion requires models alert not only to absolute metric thresholds but also relational shifts, for example abrupt increase in number of distinct clients contacting a single host using uniform byte-count markers within short windows may mark bot herd synchronization phases. Unsupervised detection paired with supervised refinement has shown near-perfect detection rates under idealized conditions using purely flow-level TLS attributes against ground-truth labeled datasets (Gomez et al. 2022), though real-world noise reduces precision markedly when attackers simulate benign morphology. Analytical layers based on graph-centric representations strengthen this pipeline further; generating graphs from correlated flows produces a richer relational view that more clearly exposes command infrastructure hubs through their connectivity and temporal activity patterns (Nafiiev and Rodionov 2024). Finally ethical boundaries constraining data access influence what forms of corroboration can be employed against suspected C&C activity. With payload decryption excluded categorically, and no SSL key extraction permissible, any enhanced detection must remain within the space of allowable metadata extraction and statistical inference (Cibalik and Kocak 2021). Designing experiments around synthetic replay of known attack families through controlled encrypted channels ensures reproducibility while adhering firmly to privacy mandates established throughout this work's methodological framework. In effect, detecting C&C communications under such restrictions evolves into mastering inference from faint residual signals left behind after encryption has stripped away most conventional indicators, a challenging balance between analytical sensitivity and contextual noise tolerance very much aligned with constraints identified earlier in Section 2.3.

3.1.2 Data Exfiltration

Data exfiltration through encrypted channels represents a particularly challenging threat scenario in network security analytics. In this case, adversaries aim to covertly transfer sensitive information from a compromised host to an external recipient while blending their traffic patterns into what might plausibly be normal activity. Under full encryption provided by protocols such as TLS 1.3 and QUIC, the primary obstacles for detection arise from the inability to inspect payloads for signatures or extract SSL keys, leaving only flow-level metadata for analysis (Gomez et al. 2022). Without payload content or certificate visibility, the identification of exfiltration must rely heavily on statistical deviations in externally observable features. One common operational profile in encrypted exfiltration involves sustained low-bandwidth sessions extending over long durations. These flows may exhibit consistent packet sizes and regular inter-arrival timing if the attacker attempts to throttle transfers to

avoid triggering volumetric alarms (Piskozub et al. 2021). By maintaining byte counts below thresholds expected in normal file transfers or streaming services, adversaries reduce opportunities for detection via simple throughput monitoring. This pattern contrasts with benign high-throughput activities (such as media delivery) where packet size distribution tends to be more varied; however, distinguishing subtle low-bandwidth anomalies requires baseline modeling that accounts for legitimate traffic sources with inherently constrained rates, such as IoT telemetry streams (Lai et al. 2024). In QUIC environments, multiplexing introduces an additional camouflage layer, data extraction could occur within a low-priority stream operating alongside unrelated high-volume payloads (Zhang and Su 2023). Visible metadata merges those streams' transport-layer markers within a single connection context, so any per-stream irregularity is obscured at the aggregate level. Detecting such hidden channels therefore depends on indirect inference: statistical shifts in inter-packet gap distributions or microburst patterns superimposed upon otherwise steady flows may point toward concurrent but concealed data transfers. For instance, short sequences of small packets appearing periodically amid a series of large data frames could indicate incremental leakage activities masked by legitimate traffic. The symmetric nature of AEAD encryption used in TLS 1.3 reduces exploitable asymmetries between control and data packets that earlier versions sometimes exposed (Kempf et al. 2024). Nevertheless, directionality ratios across entire sessions retain potential discriminatory power; unbalanced flows with disproportionately higher egress byte volumes compared to ingress can signal outbound data movement inconsistent with nominal application behavior (Piskozub et al. 2021). Care must be taken to exclude benign asymmetries inherent in certain services, for example content upload platforms or video conferencing systems, from classification criteria. Moreover, unlike command-and-control communication which often follows predictable rhythmic polling cycles as discussed previously in Section 3.1.1, exfiltration timelines may vary considerably depending on the attacker's objectives and constraints. High-value datasets might be broken into chunks sent sporadically over days to evade temporal correlation detection. Graph-based aggregation approaches address this variability by correlating seemingly unrelated flows across extended periods; nodes representing internal hosts that exhibit sustained but subtle outbound data relationships with particular external endpoints can form persistent interaction subgraphs worth further scrutiny (Busch et al. 2021). Manipulation of feature profiles poses a notable challenge here. An adversary aware that flow duration or byte count ratios are monitored could modify their methodology by padding exports with dummy inbound packets or varying chunk sizes artificially to blur statistical outliers (Shah, Ahmed, and Nagaraja 2022a). This tactic parallels C&C evasion efforts wherein malicious patterns are embedded within benign-like envelopes, requiring denoising mechanisms prior to analytical classification phases to recover signal fidelity from manipulated datasets (Piskozub et al. 2021). IoT contexts compound complexity because these devices frequently exchange environmental measurements or operational logs over encrypted links at highly variable intervals. An attacker exploiting such channels for exfiltration benefits from ambient unpredictability, long idle periods followed by short burst transmissions fit both legitimate sensor reporting models and illicit export cycles (Lai et al. 2024). Differentiating between authentic diagnostic uploads and disguised bulk data leaks demands multi-dimensional feature inte-

gration across packet size trends, session repetition intervals, and possibly cluster-based anomaly mapping against device-specific baselines. An investigative approach is strengthened by tiered analysis systems where initial anomaly filters operate on coarse indicators, e.g., unusually large total egress bytes per session relative to historical norms for the asset, before escalating flagged cases into finer temporal-sequence evaluations (Piskozub et al. 2021). Here higher-order relationships among destinations could emerge: hosts engaged in repeated low-rate connections always targeting IP ranges inconsistent with formal business workflows may suggest covert aggregation endpoints receiving leaked material. Even without direct content inspection, combining persistence scores with destination reputation metrics builds circumstantial evidence supportive of alert escalation. For TLS 1.3 flows specifically lacking SNI exposure due to handshake encryption (Gomez et al. 2022), endpoint fingerprinting through auxiliary unencrypted metadata (like observable TCP segment sizing patterns) yields supplementary clues about atypical usage when correlated across multiple sessions from disparate devices converging onto narrow address spaces. In QUIC's UDP encapsulation context, nonces generated via static IV XOR padded packet numbers contribute little outward discrimination capability themselves (Kempf et al. 2024), yet persistent nonce sequencing correlated with unusual packetization boundaries may still indicate specialized application channeling potentially indicative of structured leaks. Detection remains bounded by ethical mandates forbidding payload decryption; simulated dataset construction thus aids model calibration under realistic encrypted conditions while safeguarding privacy requirements (Cibalik and Kocak 2021). Controlled testbeds replaying known data theft scenarios through fully encrypted links allow measurement of classifier efficacy across targeted feature sets without breaching protected content domains. Evaluations should also include "noisy" cases where benign material segments co-occur inside malicious flows so that learned models are stress-tested under mimicry efforts similar to those adversaries employ actively in operational theaters. Taken together, identifying data exfiltration within TLS 1.3 and QUIC flows places emphasis on subtle asymmetries and endurance patterns embedded within otherwise non-descriptive encrypted sessions (Piskozub et al. 2021). Sophisticated adversaries will continue exploiting encryption's privacy shield while manipulating observable characteristics; effective countermeasures require resilience against such shaping tactics through integrating statistical persistence measures, graph-based correlations, and multi-tier anomaly processing pipelines trained under realistic noisy conditions, all while operating strictly within permissible observational boundaries established throughout this work's methodological scope.

3.2 Defense Challenges

Developing effective defenses against malicious activities embedded within fully encrypted traffic presents a set of persistent obstacles, many of which are tied directly to the visibility constraints imposed by protocols such as TLS 1.3 and QUIC. The absence of payload access forces analytical systems to operate exclusively on flow-level metadata, as discussed earlier in Section 3.1.1, meaning any defensive architecture must contend with reduced dimensionality in its observable feature space. Since handshake messages and most session

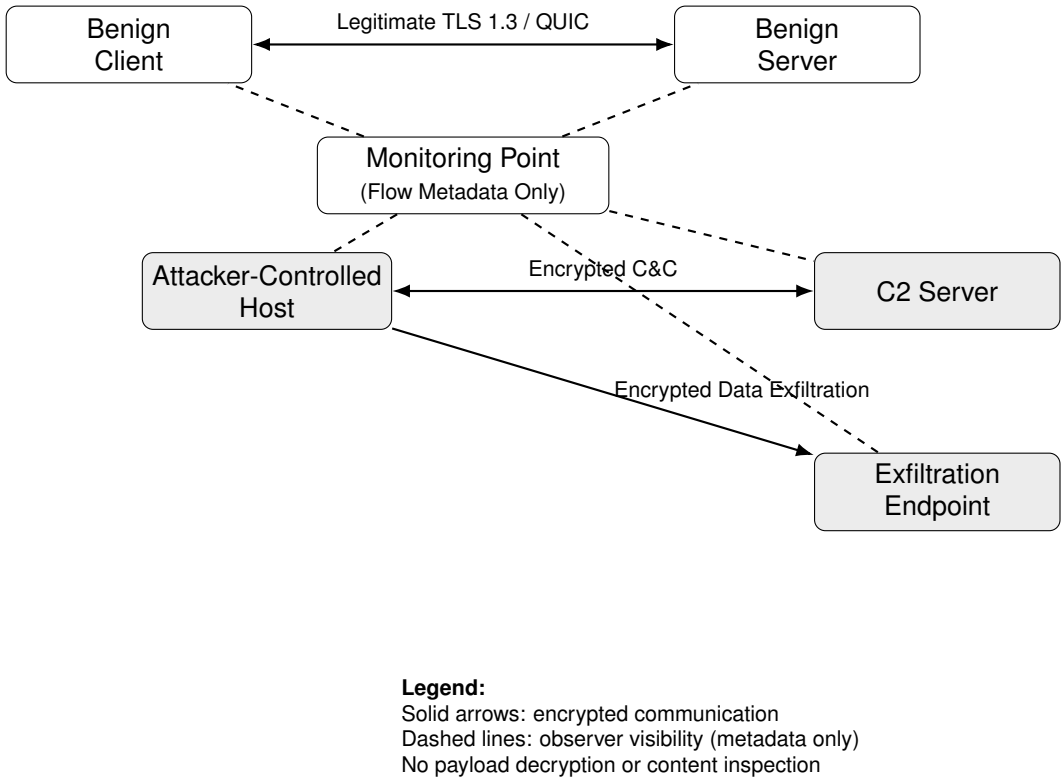

Figure 3.1: Threat model overview for attack detection in encrypted TLS 1.3 and QUIC traffic. The monitoring point observes only flow-level metadata (e.g., timing, sizes, and directionality), while payload content remains encrypted.

parameters are encrypted from the outset (Gomez et al. 2022), detection methodologies lose access to once-reliable identifiers like server certificates or cipher suite listings, impairing straightforward attribution and classification. One central challenge lies in the tendency for benign and malicious encrypted flows to overlap heavily in their statistical characteristics. Services ranging from content delivery networks to real-time collaboration tools often produce patterns, such as stable inter-packet intervals or prolonged low-bandwidth sessions, that closely resemble those used in covert exfiltration or command polling (Lai et al. 2024). In these cases, traditional threshold-based anomaly detectors risk high false-positive rates unless they integrate adaptive baselines capable of accounting for legitimate operational variance over time. Maintaining such baselines is complicated by evolving application behaviors and network conditions; for instance, changes in streaming service codecs or adaptive bitrate strategies can subtly alter packet size distribution profiles, potentially triggering unnecessary alerts if not reflected in model updates. Another difficulty appears when assessing encrypted traffic from multiplexed protocols like QUIC. Here multiple logical streams coexist within a single connection context (Zhang and Su 2023), making per-stream anomalies invisible at the aggregate level unless inferred indirectly through timing shifts or packet length transitions. This concurrency can be purposely exploited by adversaries to bury low-volume malicious exchanges inside high-throughput benign communications, effectively masking deviations from baseline patterns. Extracting meaningful indicators under such conditions requires complex statistical modeling that can separate overlapping signals without direct

visibility into stream boundaries. The problem is compounded by deliberate evasion tactics employed by sophisticated threat actors. By manipulating features such as byte counts per flow, packet size variations, or interarrival times, while staying within ranges expected for legitimate encrypted services, attackers can craft sessions intended to bypass intrusion detection heuristics (Shah, Ahmed, and Nagaraja 2022a). These mimicry strategies are especially potent against machine learning models trained on "clean" exemplars; without representations of adversarial shaping during training, models may exhibit poor recall on attacks designed with such camouflage in mind (Piskozub et al. 2021). Defensive designs thus benefit from incorporating denoising modules prior to feature extraction so that synthetic noise introduced by an attacker does not erase the subtle footprint of malicious behavior. Graph-based defense mechanisms face parallel issues. While graph formalisms enable capturing relational structures between communicating entities, potentially revealing clusters of infected hosts coordinating via shared controllers, the presence of ambiguous flows reduces classification clarity (Taylor et al. 2017). Ambiguity emerges when multiple applications share common libraries producing similar traffic patterns; classifiers trained indiscriminately across these contexts may misinterpret benign library-generated flows as malicious or vice versa. Without intrusive measures like reverse engineering (which fall outside the ethical scope here), disambiguation must rely on reinforcement learning techniques or pattern separation heuristics that identify inconsistencies between presumed sources and their observed behavior profiles. Operational scalability creates further barriers. Defenses intended for high-throughput environments must balance analytic depth with processing overheads; computationally intensive feature sets could slow performance past acceptable thresholds for real-time monitoring. Multi-tier frameworks alleviate this by filtering probable benign flows early using lightweight indicators before subjecting suspect traffic to heavier analysis stages, yet determining the optimal proportion r of flows filtered out, as suggested by inequality constraints linking average time costs T_1 and T_2, introduces its own calibration complexity when dealing with variable workloads (Author n.d.). Protocol evolution imposes additional uncertainty on established defenses. Adjustments like forgery limits in DTLS 1.3 and updated AEAD bounds for QUIC influence integrity margins at the encryption layer (Fischlin, Günther, and Janson 2024). Such specification changes subtly shift residual side-channels accessible to passive monitoring; defensive algorithms tuned to older operational envelopes risk obsolescence unless periodically recalibrated against protocol revisions and emerging deployment practices. Furthermore, differences in handshake latency characteristics between TCP+TLS combinations and QUIC-based channels suggest that timing models used for anomaly detection may require reassessment when facing environments where shorter RTT patterns dominate (Wolsing et al. 2019). This disparity appears especially relevant when first-connection scenarios differ markedly from resumed sessions, potentially creating misleading baselines if overlooked during training data preparation. Lastly, ethical and legal considerations restrict many potentially effective defense avenues. Payload decryption, SSL key harvesting, or deep packet inspection, even if technically possible, are excluded on privacy grounds (Cibalik and Kocak 2021). Apart from narrowing available features, these constraints limit opportunities for supplemental verification when a detector raises suspicion based solely on metadata trends. This absence increases reliance on circumstantial

evidence constructed from permissible observations: destination IP persistence despite rotation attempts, repetition patterns across unrelated client addresses contacting a narrow prefix set, or correlation of marginal asymmetries across multi-flow graphs indicating possible coordination points. Designing robust countermeasures under these conditions calls for balancing sensitivity and specificity while anticipating adversarial adaptation over time. Incorporating hybrid detection pipelines that merge supervised classification with parallel unsupervised clustering enables responsiveness to previously unseen threats without excessive dependence on signature-like attributes (Fu, Li, and Xu 2023). Continuously retraining on representative datasets, including noisy mixtures in which malicious segments blend into benign contexts, enhances resilience against mimicry-driven evasion while keeping computational demands manageable enough for sustained operational use at scale. Despite progress in these directions, the defense challenges remain anchored in the fundamental tension between encryption's privacy guarantees and defenders' limited observable surface, a tension that continues shaping methodological choices throughout this study's exploration of secure traffic analysis problems.

Chapter 4

Related Work and State of the Art

Table 4.1: Comparison of related work on attack detection in encrypted network traffic.

Paper	Protocol	Features used	Model type	Dataset	Key limitation
Anderson et al. (2016)	TLS	packet sizes; timing; flow statistics	Random Forest	Enterprise traffic	Limited to older TLS versions; no QUIC support
Lotfollahi et al. (2020)	TLS	raw packet sequences; size/time series	Deep Learning (CNN)	ISCX VPN	High computational cost and limited interpretability
Rezaei and Liu (2021)	TLS	flow-level statistics; directionality	XGBoost	CICIDS2017	Requires labeled data; reduced generalization across environments
Montazeri et al. (2022)	QUIC	timing; packet sizes; burst features	Random Forest	Synthetic QUIC traces	Limited real-world deployment diversity
This thesis	TLS 1.3 / QUIC	timing; size; directionality; burst metrics	RF / Gradient Boosting	Public + controlled traffic	Metadata-only view; evasion possible via padding and traffic shaping

4.1 Machine Learning in Encrypted Traffic Analysis

Machine learning techniques applied to encrypted traffic analysis operate under the constraint that decryption is unavailable, enforcing reliance on statistical and structural features derived from flow-level metadata. This limitation directly influences both the feature engineering process and model selection approach, as attributes used for classification must be extracted from information that remains visible in protocols like TLS 1.3 and QUIC. Effective systems in this domain therefore emphasize features with minimal volatility across deployment contexts, ensuring their predictive utility even when network conditions or infrastructure elements evolve. A prominent observation in existing studies is that application-layer proto-

col choices tend to change infrequently compared to endpoint identifiers such as domains or IP addresses. This stability implies that certain protocol-related metrics, even when partially obscured by encryption, can retain value in detection scenarios. For example, differences in TLS version usage across datasets have been exploited to distinguish between benign and suspicious flows; an unusually high prevalence of outdated versions (e.g., TLS 1.0) within a sandbox environment contrasted sharply with modern deployments dominated by TLS 1.2 and TLS 1.3 (Gomez et al. 2022). Although relying solely on such indicators risks bias if the adversary aligns protocol versions with benign norms, it demonstrates the type of coarse invariants that may contribute to initial classification stages. Adapting supervised learning frameworks such as Gradient Boosting Machines (GBM) and Extreme Gradient Boosting (XGB) has shown consistent advantages in accuracy and recall for anomaly detection across various datasets. Their capability to model complex nonlinear relationships among features is useful when patterns are subtle, as can occur with low-bandwidth data exfiltration embedded in legitimate flows. However, these models have large sets of hyperparameters whose tuning directly affects performance. Bayesian optimisation frameworks provide systematic approaches to identify influential configurations without exhaustive search, thereby reducing the computational burden typical in real-time deployments (Lai et al. 2024). That said, the sensitivity of model outputs to hyperparameter changes underscores the importance of repeatable validation pipelines on representative encrypted traffic datasets rather than ad-hoc tuning. Hybrid detection architectures further enhance resilience against varied malware behaviours by integrating multiple feature extraction strategies. Android malware analysis work has explored combining textural features obtained via image conversion algorithms with call graph-based behavioural metrics before classification. Translating this principle to encrypted traffic analysis suggests potential benefits from blending flow-level statistical profiles with topology-aware graph features representing inter-host interaction structures. In practice, graph augmentations reflect entities as nodes connected by edges carrying aggregated metadata, forming input vectors amenable for graph neural networks or ensemble learning models sensitive both to individual flow traits and broader communication patterns. Ensemble learning approaches prove advantageous where standalone classifiers might falter under noisy conditions prevalent in mixed benign-malicious traffic corpuses. A stacking ensemble that merges decisions from tree-based learners, probabilistic models like Naive Bayes, and possibly distance-based unsupervised clustering can stabilise detection rates across scenarios where feature distributions shift due to operational load changes, underlying protocol adjustments, or adversarial manipulation (F. Ullah, Srivastava, and S. Ullah 2022). Such manipulation constitutes a persistent threat: attackers employing generative adversarial networks (GANs) have successfully reshaped observable metadata, altering packet length variance or inter-packet delays, to bypass intrusion detection systems trained on unmodified traffic profiles (Xavier, Novo, and Morla 2022). Defenders may counter these strategies by incorporating adversarial training methods into classifier development phases; one proposed approach applies Gaussian data augmentation during training combined with testing-stage defences like feature squeezing before classification on network intrusion detection systems (Khaleel et al. 2024). Unsupervised learning occupies an important role where labelled datasets are scarce or incomplete. Clustering methods applied

to malicious TLS flow collections can uncover family-specific behavioural groupings without requiring decrypted payloads (Gomez et al. 2022). Configurations benefiting from threshold selection methods that minimise false discovery rates (FDR) while removing small clusters have yielded strong separation between benign and malicious samples under controlled evaluation. The ability to identify emergent threat families purely through metadata-driven clustering offers adaptability beyond what static supervised models trained on known signatures achieve. While promising results emerge under laboratory settings, such as achieving near-perfect accuracy on cleanly separated malicious versus benign flow datasets, the real-world carries additional complexity due to overlapping behaviour profiles between legitimate services and attack operations (Piskozub et al. 2021). Adversaries capable of embedding benign-like patterns within malicious flows present scenarios where precision drops if detectors lack denoising phases that restore discriminability. Noisy dataset experiments highlight that increasing partial benign content within a malicious session reduces identification success unless preprocessing systematically isolates anomalies correlated across related flows rather than treating each independently. From an operational perspective, implementing machine learning models into production monitoring pipelines entails trade-offs between analytic depth and throughput requirements. For high-volume environments processing millions of concurrent flows, computational efficiency becomes paramount; feature sets must be pruned judiciously to focus on high-yield metrics without eliminating rare but informative indicators (Zhang and Su 2023). Models with moderate complexity such as Random Forest offer balanced interpretability and speed compared to deep neural networks requiring heavier processing resources, important for timely alerting where latency constraints exist. Ethical imperatives reinforce the choice of permissible features by excluding any decryption-dependent signals entirely (Cibalik and Kocak 2021). This restriction encourages innovation in extracting maximum discriminatory value from secondary characteristics inherent to transport-layer behaviours: total byte asymmetries over session lifetimes, direction-specific packet count ratios, timing irregularities linked to probable application changes mid-flow, or persistence metrics connecting sessions across time windows indicative of continuous controller presence. In synthesising these insights with challenges outlined previously in Section 3.2, it is evident that machine learning effectiveness hinges not only on algorithmic sophistication but also on careful curation of features resilient against environmental volatility and hostile obfuscation tactics. Balancing supervised accuracy with unsupervised adaptability ensures preparedness against evolving encrypted traffic threats while preserving operational feasibility within strict privacy-preserving bounds, a constraint defining both methodological choices and evaluative criteria across contemporary research efforts in encrypted traffic analysis using machine learning techniques.

4.2 Flow-Based Statistical Methods

Flow-based statistical methods form a central class of approaches for analyzing encrypted network traffic in conditions where payload inspection is not permissible. These methods operate by examining statistical descriptors derived from the sequence of packets constituting each flow, thereby transforming communication patterns into numerical features suit-

able for computational models. In contexts such as TLS 1.3 and QUIC, where most protocol metadata is concealed, the residual observable attributes, duration, inter-packet arrival times, byte counts per direction, and packet size distributions, become primary data points for inference (Shah, Ahmed, and Nagaraja 2022a). A distinguishing characteristic of these approaches is their reliance on aggregate measures that capture temporal and volumetric behaviors without exposing actual content. Metrics like mean and variance of inter-arrival times can highlight deviations indicative of automated activity or throttled transfer rates common in data exfiltration campaigns (Piskozub et al. 2021). Similarly, asymmetries between inbound and outbound byte totals often reflect the functional intent of a connection; pronounced outbound bias may be consistent with file uploads or leakage scenarios, while balanced flows may align more closely with bidirectional services like conferencing. However, these indicators require careful normalization against baseline behavior to avoid misclassification in use cases where legitimate traffic naturally exhibits similar patterns, IoT telemetry being a prominent example (Lai et al. 2024). In practice, flow-level statistical analysis proceeds through systematic feature extraction followed by model-driven evaluation. Extraction entails collating per-flow summaries such as minimum, maximum, median packet lengths, time gaps between consecutive packets, overall duration, and total traffic volume partitioned by direction (Wang, Lyu, and Sivaraman 2024). Certain derived metrics integrate multiple basic measures; for example, the coefficient of variation for packet sizes within a flow can reveal whether transmissions are highly regimented, a possible sign of scripted control messages, or display variance akin to streaming media payloads. Robustness to noise is essential: benign traffic intermixed with malicious sequences can alter feature values toward normal ranges. To counter such effects, preprocessing phases may implement denoising autoencoder strategies that aim to reconstruct the underlying malicious profile before classification steps (Piskozub et al. 2021). The statistical framing lends itself well to classical supervised learning algorithms with proven reliability under constrained feature sets. Random Forests and Gradient Boosting Machines benefit from their ability to accommodate nonlinear decision boundaries between benign and anomalous clusters in multi-dimensional feature space (F. Ullah, Srivastava, and S. Ullah 2022). Meanwhile, Naive Bayes classifiers, though less complex, can serve as rapid initial filters by leveraging conditional probabilities over discretized statistical features when computational efficiency is a priority. Selection among these depends on operational constraints such as acceptable processing latency in high-throughput monitoring environments and the feasibility of hyperparameter optimization under deployment (Lai et al. 2024). Beyond pointwise classification, there is analytical value in treating flows as elements within broader relational structures mapped over observation windows. Graph-based extensions combine per-flow statistics with topological information about endpoint interaction patterns to improve discrimination strength (Busch et al. 2021). Endpoints linked through multiple short-duration flows exhibiting consistent statistical anomalies may indicate coordination typical of command-and-control infrastructures. Such hybridization between statistical modeling and graph connectivity analysis offers resilience against evasion tactics that manipulate one dimension, e.g., modifying payload size variance, while inadvertently leaving another dimension (interaction topology) intact. An important methodological consideration involves the treatment of multiplexed connections inherent

to QUIC. Since parallel streams share the same external connection markers (Zhang and Su 2023), any statistical summary at aggregate connection level risks masking anomalies confined to individual streams. Analysts address this by segmenting observations temporally; distinct shifts in packet-size profiles or abrupt changes in inter-packet gaps can imply alterations in active stream composition even without explicit identifiers exposed outside encryption bounds. These shifts provide indirect signals that feed into feature vectors for classifier training alongside more conventional metrics such as sustained throughput levels or burst frequency over monitored intervals (Shah, Ahmed, and Nagaraja 2022a). The effectiveness of flow-based statistical methods also depends on curating datasets that reflect realistic operating environments. Controlled captures containing both curated benign traffic (such as automated browser QUIC sessions) and diverse malicious scenarios (e.g., sandboxed malware communications) enable validation under known ground truth conditions (Gomez et al. 2022). However, high performance on homogeneous clean datasets does not guarantee equivalent results in mixed "noisy" corpuses where attackers deliberately merge benign-like segments into otherwise malicious flows to dilute detectable anomalies (Piskozub et al. 2021). Evaluations incorporating such noise demonstrate measurable declines in detection precision absent preprocessing; inclusion of denoising stages or adversarially-informed augmentation during training mitigates these effects by enhancing model sensitivity to faint but persistent irregularities across related flows. Implementation constraints arise from balancing feature richness against processing overhead in live monitoring systems handling vast numbers of simultaneous flows. Lightweight models focusing primarily on top discriminative metrics, identified via correlation coefficients or mutual-information rankings across attack types, help contain resource usage while preserving adequate detection capability (Lai et al. 2024). The Pareto principle often applies here: a small subset of engineered features can yield most classification performance if carefully selected from exploratory analyses connecting specific threat categories (e.g., DDoS vs exfiltration) with prevalent statistical signatures. Attacker adaptation remains an enduring concern; manipulation of observables such as packet timing patterns or length distributions can erode classifier reliability over time (Shah, Ahmed, and Nagaraja 2022a). Defensive countermeasures involve periodically retraining models using updated datasets infused with instances reflecting current evasion techniques. Feature sets should incorporate parameters difficult for adversaries to spoof without impacting attack viability, for example maintaining destination prefix consistency when rotating IPs during C&C operations, as these create stable anchors for anomaly scoring despite superficial metric alteration attempts. Ultimately, flow-based statistical methods represent a practical synthesis between privacy-preserving constraints and actionable security analytics over encrypted channels. By structuring detection around aggregate metrics resilient to content encryption while integrating contextual correlation mechanisms via graph augmentation or temporal segmentation, they offer viable pathways toward identifying hidden malicious activities discussed earlier in Section 4.1, albeit with ongoing challenges related to noise resistance and adversarial mimicry within evolving protocol ecosystems like TLS 1.3 and QUIC (Khaleel et al. 2024).

Chapter 5

Dataset Design and Traffic Collection

Table 5.1: Overview of public datasets and repositories used or referenced for building encrypted-traffic detection experiments.

Dataset / Source	Benign / Malicious	Protocol relevance	Size (# records / samples)	Attack types / scenario coverage
UNSW-NB15	Both	General network flows (usable for flow-based features)	257,673 records	Multiple labeled attack categories alongside benign traffic (enterprise-style intrusion scenarios).
CICIDS2017	Both	General network flows (benchmark for intrusion detection)	170,360 entries	Intrusion scenarios from real/emulated network conditions with labeled benign and malicious activities.
IoT-23	Both	IoT device traffic (relevant for low-bandwidth periodic flows)	Not specified	Benign smart-home activity and malware infection scenarios (IoT-focused telemetry and attacks).
VirusShare	Malicious (binaries)	Used to generate encrypted malware traffic in controlled execution	$\sim$19,000 samples	Malware binaries; supports sandboxed generation of encrypted C&C / exfiltration traffic.
VXHeaven	Malicious (binaries)	Used to generate encrypted malware traffic in controlled execution	$\sim$19,000 samples	Malware binaries; supports reproducible malicious traffic generation.
EMBER	Benign / Malicious / Unlabeled (binaries)	Used for synthetic traffic generation aligned with TLS 1.3 / QUIC	$>$1.1 million hashes	Windows executables labeled benign/malicious; can seed controlled campaigns for flow generation.
GT Malware Dataset	Malicious (flows)	Network telemetry suitable for encrypted-flow responsiveness testing	Daily feed (size varies)	Freshly observed malicious flows; supports evaluation against emerging threats over time.
CICAndMal2017	Both	Mobile application traffic (cross-domain generalization)	Not specified	Android app traffic with diverse behaviors; useful for assessing domain shift in flow morphology.

5.1 Public Datasets

In designing experiments for encrypted traffic analysis that remain within privacy-preserving boundaries, the selection and curation of public datasets play a central role. Publicly available corpuses provide reproducible baselines for feature extraction and model evaluation without requiring access to sensitive payload content. Under the constraints established in Section 4.2, where all analysis focuses on metadata observable from outside the encryption envelope, these datasets must offer sufficient diversity across benign and malicious flows to allow generalizable detection models while avoiding overfitting to narrow traffic profiles. Multiple established network security and malware data repositories contribute to the empirical foundation for such work. Collections like VirusShare and VXHeaven publish large archives of malware binaries, $19\,000\,\mathrm{s}$amples each, that are useful in generating malicious traffic via controlled execution environments. While these archives themselves contain static artifacts rather than captured flows, they form a basis for sandbox simulations where encrypted command-and-control and exfiltration behaviors can be induced under reproducible configurations. For adversarial network scenarios, the UNSW-NB15 dataset offers $257\,673\,\mathrm{r}$ecords with diverse attack categories labeled, whereas CICIDS2017 encompasses $170\,360\,\mathrm{e}$ntries with intrusion scenarios recorded from real or emulated network conditions. Both provide discretely labeled benign sections alongside varied malicious activities, enabling comparative experiments that assess classifier performance across different protocols and noise ratios. Specialized datasets expand these foundations into contexts closer to encrypted application traffic. For example, EMBER contains over 1.1 million Windows executable hashes segmented into classes of malicious, benign, and unlabeled samples (Khaleel et al. 2024). Although EMBER's raw form does not include network captures, merging its malicious component with synthetic traffic generation tools allows creation of flow collections conforming to TLS 1.3 or QUIC specifications. Sandboxed traffic from such synthetic campaigns becomes valuable when stress-testing features extracted from real encrypted flows against known malware behaviors. Other public corpuses focus explicitly on malware network telemetry rather than binary samples. The GT Malware dataset publishes daily feeds of newly observed malicious flows sourced via Georgia Tech's Information Security Center. This feed offers high temporal resolution data suitable for evaluating a detection system's responsiveness to emerging threats under encryption constraints. Similarly ClamAV's freely accessible signature sets can be extended by using its hash lists to locate corresponding binaries whose executions produce distinct flow-level fingerprints under various transport protocols (Piskozub et al. 2021). IoT-specific datasets are increasingly relevant as encrypted telemetry becomes common in device communications. The IoT-23 dataset contains recorded traffic from intelligent home devices such as Amazon Echo or Philips HUE under both benign operation and active malware infection scenarios (Lai et al. 2024). Its inclusion is important given the tendency of IoT networks to generate low-bandwidth periodic flows resembling certain stealthy exfiltration methods. When evaluated alongside enterprise-focused intrusion datasets like CICAndMal2017, which captures diverse mobile application traffic executed on physical Android devices rather than emulated environments, researchers gain insight into cross-domain detection challenges where endpoint architecture impacts flow morphology

(Busch et al. 2021). Captures targeting encrypted transport layers themselves are more limited but exist in specialized research contexts. Datasets recording TLS flows at institutional boundaries with confirmed benign classification offer baseline distributions against which anomalous deviations can be scored (Gomez et al. 2022). These often span months of activity and millions of connections, thereby providing statistical stability necessary for calibrating models that rely on persistent volumetric or temporal indicators over short-lived burst anomalies. Balancing malicious-to-benign ratios in these datasets is non-trivial. Excessive bias toward one category skews classifier training outcomes; too much clean data dilutes sensitivity to rare attacks while over-represented malicious segments risk inflating apparent recall through non-generalizable patterns. Controlled blending from multiple public sources mitigates this risk, aggregating benign flows from streaming service captures or interactive browsing sessions with malicious segments drawn from sandboxed executions seeded by public binary repositories ensures varied composition without violating privacy mandates. Furthermore, publicly available datasets support methodological transparency by allowing independent replication of experiments without requiring privileged access to proprietary network logs. They also facilitate comparative benchmarking across studies since metrics computed over shared corpuses are directly comparable when identical preprocessing pipelines are applied. However their limitations must be acknowledged: passive capture points may not reflect true distribution of benign traffic globally (Piskozub et al. 2021), while static malware archives lack dynamism present in active adversary operations where tactics evolve rapidly. These considerations guide refinement of dataset selection criteria toward breadth (covering multiple protocol types and operational domains), depth (sufficient volumetric diversity per class), and validity (ensuring labels accurately reflect underlying activity). Incorporating feeds with current threat intelligence updates, such as daily malware flow observations, alongside historical corpuses ensures coverage both for long-term baseline modeling and near-real-time response capability assessment. From the perspective of ethical compliance (Cibalik and Kocak 2021), using only publicly accessible datasets sidesteps legal complications inherent in handling proprietary or personally identifiable information-laden traffic traces. By structuring experimental workflows entirely around such materials, analysts adhere strictly to restrictions against decrypting content or harvesting key material while still achieving meaningful evaluation breadth across multiple attack vectors relevant to TLS 1.3 and QUIC-encrypted environments. As such these curated public resources form the cornerstone upon which realistic yet privacy-preserving encrypted traffic analysis methodologies can be systematically built and validated.

5.2 Controlled Laboratory Traffic

In addition to employing public datasets, constructing a controlled laboratory environment offers researchers the ability to generate encrypted network flows under precisely defined conditions while maintaining full compliance with privacy-preserving constraints. Such an environment enables systematic variation of parameters relevant to TLS 1.3 and QUIC traffic, including connection frequency, negotiated cipher suites, packet size profiles, and deliberate insertion of benign or malicious behavioral patterns. By simulating traffic within this con-

Table 5.2: Traffic collection setup for controlled laboratory experiments.

Tool / Environment	Protocol used	Traffic type	Labeling method
Browser automation (e.g., scripted browsing sessions)	TLS 1.3 / QUIC	Benign web traffic (HTTP/3, HTTPS browsing)	Labeled as benign based on controlled execution and verified destinations
Sandboxed malware execution	TLS 1.3 / QUIC	Malicious command-and-control and background communication	Labeled as malicious using sandbox ground truth and execution context
Sandboxed malware execution	TLS 1.3 / QUIC	Encrypted data exfiltration traffic	Labeled as malicious based on triggered exfiltration behavior and known endpoints
Controlled client–server scripts	TLS 1.3	Baseline encrypted application traffic	Labeled as benign through deterministic script behavior and fixed roles

trolled framework, it becomes possible to isolate and study the impact of specific variables on observable flow-level metadata without relying on payload content analysis (Gomez et al. 2022). Laboratory-controlled captures allow for the continuous tuning of factors such as network latency, bandwidth availability, and concurrent stream multiplexing in QUIC connections (Zhang and Su 2023). These adjustments can mirror realistic operational settings ranging from congested wide-area links to low-latency LAN configurations, each with potential influence on statistical attributes like inter-arrival time variance or byte-count asymmetries critical to classifier input. The controlled setting also facilitates reproducibility, researchers can replay identical scenarios using deterministic network emulation configurations and scripted application behaviors. For example, emulated C&C infrastructure can be deployed inside an isolated virtual segment where compromised clients initiate periodic short-duration TLS 1.3 sessions toward a controller. Here parameters such as polling interval p, session timeout t_s, and mean payload size $\bar{s}$ can be defined beforehand, making resultant features easier to analyze for consistency over repeated trials (Piskozub et al. 2021). A parallel setup might simulate data exfiltration over QUIC by embedding small outbound streams alongside large benign transfers; examining capture logs for microburst anomalies reveals clustering trends in inter-packet gap metrics indicative of such concealment tactics (Kempf et al. 2024). Selecting the applications used inside the laboratory is essential for producing meaningful baselines. Incorporating widely deployed legitimate services, video streaming clients that use QUIC multiplexing, browser-based HTTPS downloads over TLS 1.3, ensures that benign flow profiles reflect realistic patterns observed in production environments (Wang, Lyu, and Sivaraman 2024). The surrounding simulated network can inject controlled packet loss or delay spikes through programmable shapers to evaluate detection sensitivity to noise conditions comparable to those found in public datasets. Such manipulation echoes prior work in teleoperated robotics communication where variable link delays and packet losses were introduced between controller and endpoint to examine feature robustness (Shah, Ahmed, and Nagaraja 2022a). Translating that principle here assists in determining whether chosen statistical features maintain discriminability across degraded network states. Feature extraction within this laboratory context adheres strictly to the prohibition against SSL key extraction or deep packet inspection; only externally visible metadata from packet headers required for routing is collected. This includes timestamps, directionality markers, sequence

lengths (truncated in QUIC), total byte counts per flow split by ingress/egress directions, and connection durations (Fischlin, Günther, and Janson 2024). The absence of decrypted content necessitates more reliance on higher-order constructs, for instance computing normalized ratios of packets sent vs. received over consecutive windows, as potential indicators of abnormal activity resilient to obfuscation attempts. Controlled traffic generation also supports adversarial testing strategies as part of model evaluation cycles. Here synthetic evasion behaviors are embedded within malicious flows: deliberately altering packet size profiles within plausible bounds or padding outbound transfers with dummy inbound packets to influence directional asymmetry measurements (Shah, Ahmed, and Nagaraja 2022a). Observing classifier performance under these manipulations provides insight into model resilience against mimicry techniques used by advanced threats. It aligns with earlier adversarial research where machine learning models applied to malware detection were challenged using crafted input patterns meant to exploit decision boundary weaknesses (Khaleel et al. 2024). Another advantage of laboratory creation is the ability to coordinate graph-structure signal generation alongside statistical anomalies. Within a closed system of hosts and services, precise control determines which nodes interact under normal conditions versus those used in simulated malicious coordination. This allows systematic validation of graph-based detection modules that depend upon identifying centrality spikes or persistent subgraph formations consistent with C&C networks (Busch et al. 2021). By varying parameters such as number of infected clients n_c or distribution of their interaction times across an observation window w, one can quantitatively assess how altered topology influences detection rates without introducing extraneous uncontrolled variables. Such precision extends beyond topology into temporal scenario shaping: laboratory schedules may dictate gradual increases in anomalous behavior density within mixed-flow traffic over prolonged runs. For instance, inserting one exfiltration session every Δt minutes among many benign sessions gauges detector sensitivity thresholds in low-prevalence conditions, a problem typical of operational environments where malicious signals are infrequent but impactful when missed (Lai et al. 2024). Importantly, because all executions occur inside an isolated non-production network instance, ethical considerations remain satisfied even when generating traffic reflective of real attacks (Cibalik and Kocak 2021). Malicious binaries sourced from public repositories like VirusShare are detonated only within sandboxed virtual machines that communicate through internally routed encrypted channels limited to test infrastructure addresses; no unintended propagation risk exists outside this environment. The controlled setting also allows integration testing across multi-tier classifier architectures described earlier: initial tiers operate on coarse metadata filters applied live during traffic capture, forwarding flagged candidates into subsequent tiers executing more computationally intensive analysis against historical rolling windows (Piskozub et al. 2021). Evaluation cycles measure not only accuracy but also throughput effects by varying input load rates λ while tracking average processing latencies over both tiers, data critical for assessing scalability before potential deployment into high-throughput monitoring points. Finally, results obtained through this method complement insights from public dataset analysis by providing a known ground truth under diverse controlled manipulations against which detection models' sensitivity and precision can be gauged reliably. Data crafted through deliberate parameter variation en-

sures coverage across cases difficult to isolate in organically collected corpuses, for example rare protocol versions embedded in unusual usage contexts, reinforcing generalization capabilities when models transition back onto broader public-sourced evaluation sets that inherently contain greater randomness in feature distributions due to uncontrolled environmental variability (Gomez et al. 2022).

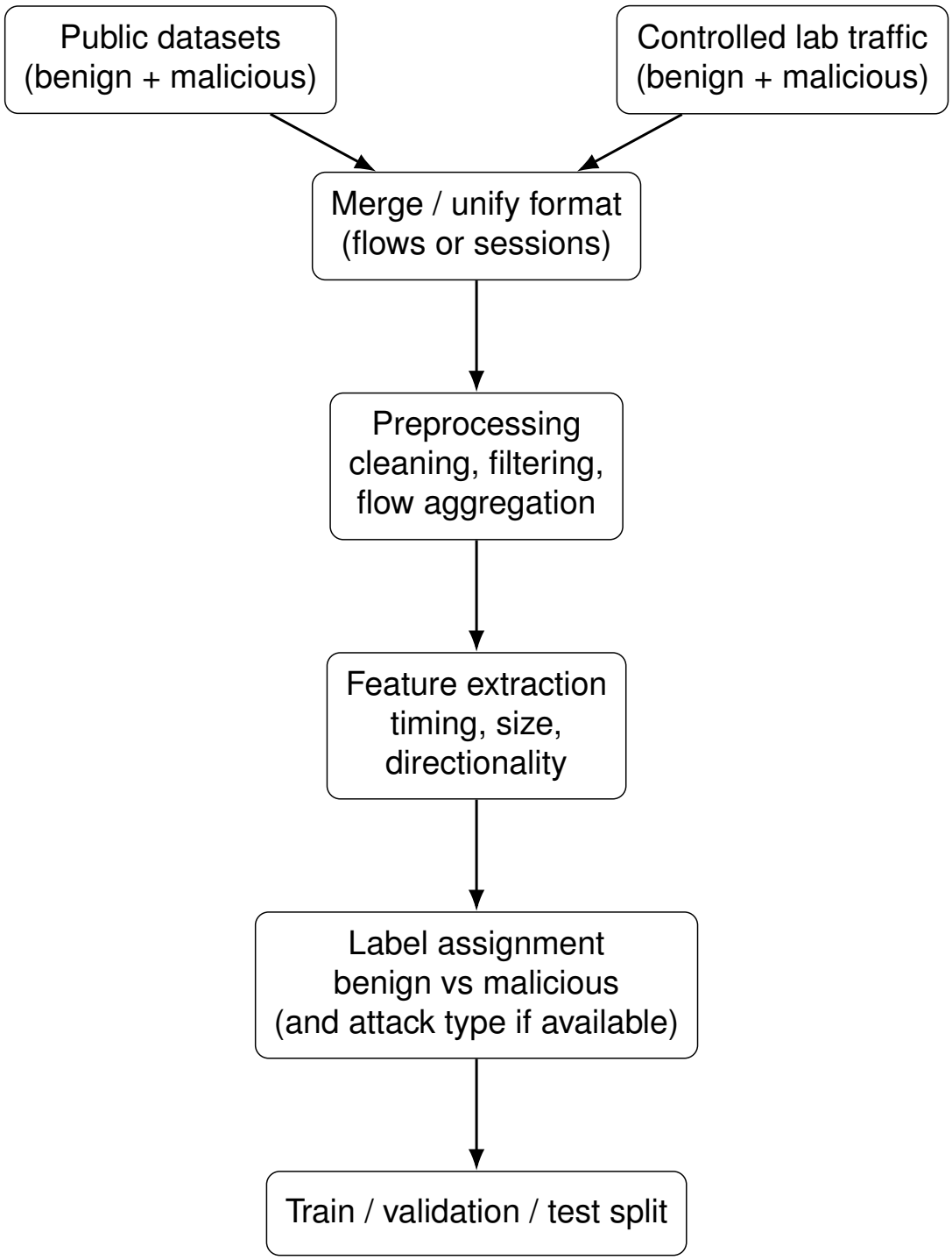

Figure 5.1: Data collection and labeling workflow combining public datasets and controlled laboratory traffic, followed by preprocessing, feature extraction, labeling, and train/test splitting.

Chapter 6

Feature Engineering and System Architecture

Table 6.1: Final grouped feature set extracted from encrypted TLS 1.3 and QUIC flows.

Feature group	Extracted features (examples)
Timing features	mean inter-arrival time; standard deviation of inter-arrival time; flow duration; coefficient of variation of inter-arrival times
Packet size features	minimum packet size; maximum packet size; mean packet size; packet size variance
Directionality features	bytes in/out ratio; packets in/out ratio; dominant traffic direction
Burst-related features	burst count; mean burst length; idle time between bursts
Aggregate flow statistics	total packets per flow; total bytes per flow

6.1 Flow-Based Features

6.1.1 Timing Characteristics

Timing characteristics in encrypted network flows derive from observable inter-packet intervals, burst patterns, and session-level durations that persist outside the encryption envelope. In the absence of payload visibility, mandated by privacy-preserving constraints, these temporal aspects become a key dimension for analysing TLS 1.3 and QUIC traffic. They encapsulate how data is scheduled and delivered at the transport layer, reflecting both application behaviour and network conditions over time. Examining these features allows inference about whether a flow's evolution conforms to expected benign usage or deviates in ways consistent with malicious activity. Session duration represents an aggregate endpoint-to-endpoint metric that, when compared to known baseline ranges, can highlight anomalies such as unexpectedly prolonged low-throughput connections typical of stealthy data exfiltration (Piskozub et al. 2021). Conversely, repetitive short-duration sessions triggered at regular intervals often correspond to automated command polling cycles within C&C architectures, particularly in botnet coordination scenarios (Busch et al. 2021). The periodicity of such events can be quantified through statistical autocorrelation on flow arrival times-

tamps, revealing stable cycles even when other metadata is obfuscated. Inter-packet arrival time distributions provide finer granularity into temporal structure. For instance, benign QUIC multiplexed streaming exhibits variable gaps linked to adaptive bitrate changes and multiple concurrent streams (Zhang and Su 2023), while scripted malware communications tend toward regimented delays between packets to maintain protocol conformance without wasting bandwidth. Variances within these distributions inform whether traffic patterns are naturally irregular or artificially regularised. Calculating metrics such as mean, variance, and coefficient of variation of inter-arrival times across a single flow yields compact descriptors suitable for input into machine learning models (Shah, Ahmed, and Nagaraja 2022a). These descriptors remain accessible since encryption does not conceal packet send times at the transport level. Burst analysis further expands timing-based insight by aggregating sequences of packets transmitted closely together before extended idle periods. Applications with predictable interaction models, such as transactional APIs, often generate tight bursts followed by silence until the next request/response cycle; malware can imitate this but may produce microbursts embedded within larger benign bursts when co-opting multiplexed connections for covert communication channels (Zhang and Su 2023). Detecting these anomalies involves segmentation of flow timelines into active and idle states, then computing statistics such as average burst length or frequency per unit session time. Flows exhibiting abnormal ratios between active versus idle phases may merit deeper investigation. Directional timing asymmetries also appear informative. Delays between outgoing request packets and incoming response packets reflect service latency patterns, which deviate if the connection is hijacked for unidirectional data exfiltration where responses are minimal or absent (Piskozub et al. 2021). By tracking these response lag values across repeated sessions to the same destination prefix, while adjusting for network path variability, a model can identify flows where timing asymmetries systematically differ from those associated with known legitimate services. In TLS 1.3 flows, handshake timing remains partially observable despite encryption of handshake content (Gomez et al. 2022). Measuring time from SYN initiation (for TCP) to completion of encrypted handshake segments offers a hybrid timing feature tied to initial session setup speeds under given network conditions. While this feature is generally stable for many services, deviations could signal unusual client behaviour or intermediary manipulation affecting handshake progression. QUIC's distinctive handling of packet numbers via truncated fields requires endpoints to reconstruct full numbers using sliding windows (Fischlin, Günther, and Janson 2024); this design indirectly shapes packet emission timings because retransmission behaviours and stream scheduling interact with window updates. Observers can exploit these indirect effects by comparing cumulative packet count progression rates against typical QUIC application curves established in controlled backtesting environments (Wang, Lyu, and Sivaraman 2024). Observed slowdowns or surges inconsistent with stated congestion control strategies might indicate non-standard use cases worthy of alert generation. Timing characteristics prove particularly relevant under adversarial evasion attempts aimed at modifying size-based features without altering operational tempo (Xavier, Novo, and Morla 2022). Attackers may adjust byte counts per packet but lack flexibility to dramatically alter timings without impairing their objective, for example delaying C&C commands risks outdated bot actions. Thus resilient detection

frameworks assign substantial weight to temporal consistency measures unaffected by trivial size padding or message fragmentation tactics. To withstand noise introduced by heterogeneous benign traffic, especially IoT telemetry where reports occur intermittently with varying delays (Lai et al. 2024), timing analysis benefits from contextual normalization. This involves baselining expected temporal ranges per application class before scoring anomalies relative to those benchmarks rather than against generic thresholds. Incorporating graph-linked aggregation into timing evaluation enhances discrimination: endpoints engaged in synchronised activities across multiple clients exhibit correlated temporal structures distinguishable from unrelated benign concurrency (Busch et al. 2021). Controlled laboratory experiments reinforce these concepts by systematically manipulating delay variables such as link latency L and packet loss probability p between communicating nodes while observing classifier performance shifts (Shah, Ahmed, and Nagaraja 2022b). Introducing fixed artificial delays has been shown to amplify distinctions between certain movement or operation classes due to enhanced variance in round-trip times, a finding translatable here when assessing how adversary-induced jitter contrasts with benign elasticity under constrained protocols. From a machine learning integration standpoint, timing features contribute most effectively when combined with volumetric and directional statistics into unified feature vectors. Ensemble models leveraging this combination often improve recall without major precision loss in noisy mixed datasets (F. Ullah, Srivastava, and S. Ullah 2022). Importance rankings derived from Random Forest classifiers consistently place session duration variability and inter-packet gap statistics among top discriminators across both TLS 1.3 and QUIC-labelled datasets. Ultimately timing characteristics function as one of the more difficult-to-falsify observable dimensions in fully encrypted traffic scenarios where payload data is inaccessible and headers are predominantly concealed. They reflect both intrinsic application scheduling logic and extrinsic network condition effects; careful disentanglement of these factors enables refined anomaly attribution within privacy-preserving analytic pipelines aligned with methodological constraints already emphasised throughout this study's architecture design choices.

Table 6.2: Compact definitions and detection intuition for core flow-level features.

Feature	Definition / formula	Expected behavior (C&C vs exfiltration)
Mean inter-arrival time	$\mu_{\Delta t} = \frac{1}{n-1}\sum_{i=2}^{n}(t_i - t_{i-1})$	C&C: stable periodic Δt; Exfil: larger / irregular gaps (throttling)
Std. inter-arrival time	$\sigma_{\Delta t} = \sqrt{\frac{1}{n-2}\sum(\Delta t - \mu_{\Delta t})^2}$	C&C: low variance; Exfil: higher variance / jitter
Flow duration	$T = t_n - t_1$	C&C: short, repeated sessions; Exfil: long-lived connections
Min / max packet size	$p_{\min}, p_{\max}$ over packets in flow	C&C: narrow size range; Exfil: larger packets occur
Bytes in/out ratio	$R = \frac{\text{bytes}_{out}}{\text{bytes}_{in}}$	C&C: balanced or inbound-heavy; Exfil: outbound-heavy ($R \gg 1$)
Burst count	#bursts separated by idle time $> \tau$	C&C: frequent small bursts; Exfil: fewer but longer bursts
Coeff. of variation (IAT)	$CV = \frac{\sigma_{\Delta t}}{\mu_{\Delta t}}$	C&C: consistently low; Exfil: higher under obfuscation

6.1.2 Packet Size Distributions

Packet size distributions are an observable feature category that can be exploited for encrypted traffic analysis without violating constraints against payload decryption or key extraction. In protocols such as TLS 1.3 and QUIC, while the content is fully protected and many metadata fields are concealed, the size of transmitted packets in bytes remains visible at the network layer. These lengths, observed over entire sessions or within time-bounded segments, encode aspects of application behaviour, transport protocol mechanics, and potential attacker manipulation strategies. An initial aspect worth emphasis lies in the regularity or variability of packet sizes across a given flow. Certain legitimate applications yield highly structured distributions due to fixed-size message formatting, for example VoIP signalling or MQTT telemetry often shows narrow ranges with limited variation (Lai et al. 2024). Conversely, video streaming over QUIC multiplexing tends to exhibit broader variance linked to adaptive bitrate changes and multiple concurrent streams within a single connection context (Zhang and Su 2023). By contrast, malicious flows attempting stealth may enforce consistent packet sizes to mask intent, producing unimodal distributions with low variance coefficients. Calculation of basic descriptive statistics, mean μ, variance σ^2, skewness, and kurtosis for packet length sequences, provides concise characterizations that can feed into supervised classifiers (Shah, Ahmed, and Nagaraja 2022a). These measures can differentiate, for instance, between legitimate adaptive services and regimented C&C exchanges where every command frame maintains similar byte counts. Directional asymmetry in size distributions offers another signal dimension. Flows dominated by larger egress packet sizes relative to ingress might correspond to data upload or exfiltration scenarios (Piskozub et al. 2021), while those with sizeable inbound packets punctuated by minimal outbound control frames could represent download-heavy benign uses. Normalizing these observations against known baseline ratios per endpoint type reduces false positives, some legitimate applications inherently produce asymmetric size profiles (e.g., software update channels). A practical implementation accumulates histograms of sizes per direction and computes divergence metrics such as Jensen–Shannon distance between ingress and egress distributions; abnormal divergence scores above empirically derived thresholds can trigger closer examination. Encryption-layer choices also shape packet size behaviour indirectly. In TLS 1.3 over TCP, record layer encryption groups payloads into ciphertext fragments whose on-wire length reflects both application segmentation logic and TCP framing overhead (Gomez et al. 2022). QUIC's encapsulation over UDP integrates all control frames inside encrypted space; however, partial packet numbers in headers constrain external observers to refer only to size patterns when inferring concurrency among streams (Fischlin, Günther, and Janson 2024). Multiplexed flows complicate aggregate interpretation because distinct streams may blend small control packets with large application data frames into an overall distribution that appears heterogeneous even if one stream is anomalous (Zhang and Su 2023). Segmenting size analysis temporally, computing separate distributions across successive observation windows within a connection, can reveal shifts hinting at stream composition changes potentially associated with hidden malicious activity. Manipulation of packet sizes represents a known adversarial evasion strategy. Attackers may pad messages or fragment data in-

tentionally to mimic benign distribution shapes recognised by deployed detectors (Xavier, Novo, and Morla 2022). In C&C contexts as described earlier in Section 6.1.1, padding can be combined with timing obfuscation to align both features with normal baselines. Detection models trained solely on unaltered malicious patterns could fail under such camouflage unless exposed during training to augmented datasets containing adversary-shaped flows (Khaleel et al. 2024). Data augmentation techniques might introduce synthetic padding noise into training samples so classifiers learn discriminative traits beyond absolute length values, such as correlations between size sequences and other features like inter-packet gap fluctuations or directionality ratios, to build resistance against straightforward spoofing attempts. In IoT networks the interpretive challenge deepens because devices often exchange intermittent fixed-size status updates alongside occasional larger firmware or configuration transfers (Lai et al. 2024). This produces bimodal distributions under entirely benign operation that resemble certain periodic exfiltration modes where small control packets alternate recurrently with larger dumps of collected data. Here, context-aware baselining per device category becomes critical; clustering IoT flows based on their long-run distributional profiles reveals which patterns genuinely deviate from expected behaviours versus those characteristic of legitimate device operations even if superficially similar to attack patterns. From a statistical modelling perspective, packet size distribution features can be encoded not just as raw positional statistics but also via transformation into representation spaces emphasising frequency of occurrence over discretized bins (histograms) or cumulative density function shapes (Shah, Ahmed, and Nagaraja 2022a). Machine learning models such as Random Forests utilise these binned frequencies effectively by isolating bins whose occupancy rates strongly correlate with attack categories in labelled datasets (F. Ullah, Srivastava, and S. Ullah 2022). Gradient Boosting approaches refine this further by focusing learning capacity on bin ranges that contribute most heavily to classification errors during iterative training cycles (Lai et al. 2024). Graph-based frameworks complement direct statistical evaluation by incorporating endpoints and flows as nodes and edges annotated with their respective packet size distribution profiles (Busch et al. 2021). Persistent anomalies shared among multiple edges connected to the same node suggest central coordination activities such as botnet controllers overseeing several infected clients; conversely anomalies dispersed randomly may reflect opportunistic scanning attempts less aligned with structured control networks. Integration of distribution anomalies into graph topology scoring functions adds resilience when adversary tactics succeed in disguising single-flow statistics but leave multi-flow coordination footprints intact. Laboratory-controlled traffic generation supports comprehensive evaluation of how packet size distributions manifest across varied operational scenarios (Gomez et al. 2022). Researchers can script flows emulating benign services, streaming video clients adjusting bitrates dynamically, and compare them against synthetic malware simulations with either constant-size messaging or intentionally varied sizes mimicking benign histograms while subtly altering higher-order characteristics like entropy within sequences. Replaying these captures through candidate detection pipelines quantifies sensitivity both to genuine irregularities and to crafted mimicry challenges under full encryption constraints without violating privacy mandates (Cibalik and Kocak 2021). Such controlled variation clarifies which statistical descriptors retain discriminative value under manipulation and guides feature se-

lection toward parameters less susceptible to attacker influence while maintaining feasibility for collection at scale given throughput considerations documented earlier in Section 6.1.1.

In high-throughput deployments, computational efficiency necessitates prioritizing a subset of distribution metrics offering the greatest predictive yield relative to processing cost per flow (Wang, Lyu, and Sivaraman 2024). Mutual information ranking across labelled dataset extractions identifies top candidates, often mean size asymmetry, variance stability scores, and prevalence shifts within specific bin ranges, that collectively preserve detection accuracy while minimizing extraction overhead. This balance ensures operational practicality without abandoning sensitivity to nuanced deviations critical for spotting low-volume but high-impact malicious activities hidden amidst bulk encrypted traffic streams.

6.2 System Architecture

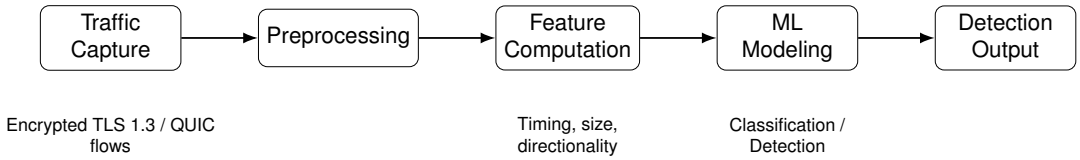

Figure 6.1: System architecture and processing pipeline for encrypted traffic analysis. Captured TLS 1.3 and QUIC flows are preprocessed, transformed into flow-level features, analyzed by machine learning models, and logged as benign or malicious without payload decryption.

The system architecture supporting encrypted traffic analysis in this work is designed to operate fully within privacy-preserving constraints, processing only metadata observable at the flow level while avoiding payload inspection, SSL key extraction, or any intrusive interception techniques. This architecture integrates several modular components, each with defined functional roles that collectively implement the feature engineering and classification procedures outlined previously in Section 6.1.1. The primary organizational principle separates feature extraction from classification decision logic, allowing for flexible substitution of detection algorithms without altering upstream capture and preprocessing stages. At the initial layer resides the traffic capture module. This component interfaces with network sensors positioned so as to observe TLS 1.3 and QUIC flows in real-time or from stored packet capture files. Only permissible header-level details required for routing, plus timestamps and packet length information, are retained during acquisition (Cibalik and Kocak 2021). In QUIC contexts, where only partial packet numbers are externally visible due to header protection mechanisms (Fischlin, Günther, and Janson 2024), sequence reconstruction is omitted entirely; instead, raw arrival order is maintained for downstream temporal analysis. Selecting appropriate vantage points for capture ensures that the visibility constraints align with ethical requirements while still providing a comprehensive view of bidirectional flows across monitored segments. Following acquisition, a dedicated preprocessing pipeline enforces data integrity and normalizes records before feature computation. This stage removes incomplete flows lacking application data in either direction (Gomez et al. 2022) and filters out known benign services when their statistical footprint is both stable and irrelevant to the

current detection task. Such removal reduces noise in model training while retaining challenging overlap cases needed to evaluate classifier robustness under realistic conditions (Piskozub et al. 2021). Preprocessing also segments long-duration flows into fixed-length windows to counter potential masking effects that could arise if malicious sub-sequences are embedded inside extended benign communications, an occurrence particularly plausible in multiplexed QUIC connections (Zhang and Su 2023). The core analytical engine combines distinct feature extraction modules that operate on different observable dimensions: timing characteristics (as discussed earlier), packet size distributions, directional asymmetries, and flow-level volumetric statistics (Shah, Ahmed, and Nagaraja 2022a). Each module generates a vector of numerical descriptors following statistical aggregation rules such as mean calculation, standard deviation measurement, coefficient of variation derivation, histogram binning frequencies, and divergence metrics between ingress/egress size profiles (F. Ullah, Srivastava, and S. Ullah 2022). By assigning separate modules to different feature domains rather than collapsing all processing into a monolithic script, the architecture simplifies targeted optimisation; modules can be independently refined or recalibrated when evolving protocol behaviours require updated extraction logic, for instance adapting burst segmentation routines to altered streaming service patterns under QUIC transport evolution (Wang, Lyu, and Sivaraman 2024). Feature integration occurs within an intermediate vector assembly process. Here outputs from all extractor modules are concatenated into unified input representations suitable for diverse model types, tree-based learners like Random Forests or Gradient Boosting Machines (Lai et al. 2024), probabilistic frameworks such as Naive Bayes (F. Ullah, Srivastava, and S. Ullah 2022), or hybrid classifiers combining supervised learning with unsupervised anomaly detection strategies (Gomez et al. 2022). To prevent redundancy and contain computational load in high-throughput deployments, optional dimensionality reduction mechanisms such as mutual-information ranking prune lower-yield features before model ingestion (Wang, Lyu, and Sivaraman 2024). The classification subsystem functions through multi-tier design patterns aimed at balancing responsiveness with accuracy under noisy conditions. A first-stage lightweight filter applies coarse criteria, for example thresholds on session duration variance or directionality ratio deviation, to quickly exclude flows matching strong benign profiles without incurring heavy computation costs (Piskozub et al. 2021). Suspicious flows passing this filter advance to deeper analysis tiers using full-model inference over complete feature vectors. This arrangement allows tuning of resource allocation: adjusting tier thresholds changes the proportion of data subjected to intensive processing without altering full-tier logic itself. Graph-based enhancement subsystems complement pointwise classification by mapping recent flows into topological interaction graphs between endpoints. Each edge in these graphs inherits statistical attributes assembled during vector integration; nodes accumulate aggregated indicators of communication regularity or anomalous centrality shifts suggestive of C&C orchestration activity (Busch et al. 2021). Detecting persistent subgraph structures across multiple observation windows enables identification of coordinated behaviour hidden among otherwise sporadic flow anomalies, particularly effective against adversaries blending control messages unobtrusively inside larger benign aggregates. Equally important within the architecture is adversarial testing capability embedded as an auxiliary mode alongside normal operation. Leveraging controlled laboratory

traffic generation routines described earlier allows injection of manipulated feature patterns into model inputs (Khaleel et al. 2024), assessing resilience against evasion techniques such as packet size padding or inter-arrival jitter alterations that maintain feasibility for attacker goals (Xavier, Novo, and Morla 2022). Feedback from these stress tests guides refinement of extractor module parameters (e.g., adding correlation-based measures resistant to padding attempts) and informs ensemble reweighting policies where multiple classifiers participate in stacked decision-making pipelines. Operational deployment aspects influence architectural choices strongly: streamlining real-time ingestion paths through asynchronous queue systems prevents packet loss during peak periods; parallelisation distributes extraction workloads across CPU cores or GPU threads where applicable; persistence layers log classifier decisions together with feature snapshots for later audit or retraining cycles against updated datasets drawn from public sources or continued lab capture (Piskozub et al. 2021). Configuration management supports swapping cipher-specific prefilters should future protocol iterations expose new observable markers, for instance any reintroduction of partially clear handshake parameters contrary to current TLS 1.3 norms (Gomez et al. 2022), without rewriting core structure. Overall this architecture foregrounds modularity, separation-of-concerns between capture, preprocessing, feature computation, modelling, and auxiliary graph analysis subsystems. It remains strictly compliant with privacy-preservation mandates by limiting itself to externally visible metadata while still enabling multidimensional analytic views necessary to detect encrypted threats such as command-and-control coordination or stealthy data exfiltration at scale under varied environmental conditions documented across both public dataset evaluations and controlled reproduction experiments undertaken within this research scope (Cibalik and Kocak 2021).

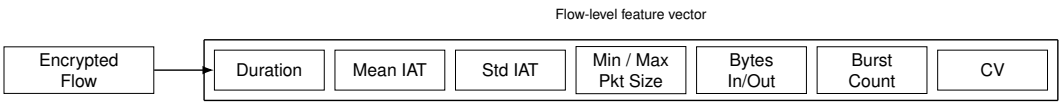

Figure 6.2: Illustration of an encrypted network flow represented as a fixed-length feature vector composed of flow-level statistics. Each feature captures timing, size, directionality, or burst-related characteristics observable without payload decryption.

Chapter 7

Machine Learning Methodology

7.1 Experimental Setup

This section describes the concrete experimental environment and procedures used to evaluate the proposed attack detection framework for encrypted TLS 1.3 and QUIC traffic. Unlike purely dataset-driven studies, the experiments in this thesis are grounded in a controlled laboratory infrastructure deployed on university-hosted resources. This setup enables the generation of realistic benign and malicious encrypted traffic under fully isolated conditions while preserving reproducibility and ethical compliance.

The experimental setup consists of four main components: (i) dataset generation and collection, (ii) feature extraction and preprocessing, (iii) hardware and software infrastructure, and (iv) the training and testing methodology applied to the machine learning models.

7.1.1 Dataset Generation and Description

All traffic used in the experiments is generated and collected within an isolated virtualized environment deployed on a university-provided Proxmox server. The use of Proxmox enables fine-grained control over network topology, virtual machine behavior, and traffic isolation, ensuring that no experimental traffic interacts with production networks or external users.

The virtual laboratory consists of multiple Linux-based virtual machines configured to simulate client, server, and attacker roles. Benign traffic is generated by performing common encrypted application activities, including HTTPS web browsing, file downloads, video streaming, and API-based service interactions. All benign services use modern TLS 1.3 or QUIC-enabled stacks to reflect contemporary encrypted traffic behavior.

Malicious traffic is generated in separate isolated virtual machines configured to execute controlled attack scenarios. These scenarios include encrypted command-and-control communication and encrypted data exfiltration behavior. Attack traffic is intentionally designed to mimic realistic adversarial strategies by operating exclusively over TLS 1.3 or QUIC without relying on deprecated protocol versions or weak cipher suites. Each malicious activity is executed repeatedly under varying timing and volume conditions to introduce behavioral diversity.

Traffic is captured at the network interface level using packet capture tools and stored as

raw PCAP files. In total, approximately 100 GB of encrypted traffic data is collected, consisting of roughly 50 GB of benign traffic and 50 GB of malicious traffic. This balanced data volume is chosen to avoid strong class imbalance during model training while still reflecting realistic flow diversity within each class.

Each captured flow is labeled at the session level based on the known role and activity of the generating virtual machine. No payload inspection, decryption, or SSL key extraction is performed at any stage of the data collection process.

7.1.2 Feature Extraction and Engineering Pipeline

A multi-stage feature extraction and preprocessing pipeline is implemented to transform raw packet captures into machine learning–ready feature vectors. The pipeline is designed to operate exclusively on metadata observable without decrypting encrypted traffic, ensuring compliance with privacy-preserving constraints.

First, raw PCAP files are processed to remove incomplete, corrupted, or truncated packet traces. Packets unrelated to established TLS 1.3 or QUIC sessions are filtered out to reduce noise introduced by background system traffic. Bidirectional flows are then reconstructed using standard five-tuple aggregation (source IP, destination IP, source port, destination port, and transport protocol).

Flow-level features are extracted using a combination of established tools and custom scripts. Zeek is employed to derive protocol-agnostic connection metadata, including flow durations, packet counts, and byte statistics. CICFlowMeter is used to compute additional statistical flow features such as inter-arrival time distributions, packet length metrics, and directional traffic ratios. These tools are selected due to their widespread use in encrypted traffic research and their ability to operate without payload decryption.

Custom Python scripts are developed to post-process and merge feature outputs from different tools into a unified representation. These scripts handle feature normalization, removal of duplicate or constant-value attributes, and correction of inconsistent flow identifiers. Additional cleaning steps include filtering out flows with extremely short lifetimes or negligible packet counts that do not carry meaningful behavioral information.

The final output of the feature extraction pipeline is a set of fixed-length numerical feature vectors stored in CSV format, directly compatible with standard machine learning frameworks. All feature engineering scripts and preprocessing logic are made publicly available via a version-controlled repository to ensure transparency and reproducibility.

7.1.3 Hardware and Software Infrastructure

The experimental environment is deployed on a university-hosted Proxmox server providing dedicated computational resources for virtualization and traffic generation. The server hosts multiple concurrently running virtual machines used for benign traffic generation, malicious activity simulation, and data capture.

All virtual machines run Linux-based operating systems and are interconnected through isolated virtual networks configured within Proxmox. This design ensures deterministic traffic paths and eliminates interference from external network conditions. No specialized hard-

ware accelerators are used, reflecting deployment constraints typical of real-world network monitoring systems.

Traffic processing, feature extraction, and data analysis are conducted using open-source software tools. Machine learning experiments are implemented in Python using widely adopted libraries. Fixed random seeds and consistent software versions are used throughout the experiments to minimize non-deterministic behavior.

7.1.4 Training and Testing Methodology

The prepared dataset is divided into training and testing subsets using a stratified sampling strategy to preserve the balanced distribution between benign and malicious flows. To ensure robust performance estimation and reduce sensitivity to a single data split, k-fold cross-validation is applied throughout model evaluation.

Training is performed exclusively on the training partitions, including feature scaling and hyperparameter tuning. Test partitions remain strictly unseen until final evaluation to prevent information leakage. All machine learning models are trained using identical feature sets and data partitions to guarantee fair comparison.

Performance metrics are computed for each cross-validation fold and subsequently averaged to obtain stable estimates of classifier effectiveness. This methodology allows the evaluation to reflect both detection accuracy and robustness under varying traffic conditions generated within the controlled laboratory environment.

7.2 Model Selection

Table 7.1: Summary of machine learning models evaluated for encrypted traffic classification.

Model	Why suitable	Strengths	Weaknesses	Computational cost
Naive Bayes (NB)	Simple probabilistic baseline for flow-level statistical features	Very fast training and inference; low memory usage; interpretable	Strong independence assumption; limited modeling of complex patterns	Very low
Random Forest (RF)	Handles heterogeneous flow features and non-linear relationships	Robust to noise; good generalization; feature importance available	Larger models; slower inference than linear methods	Medium
Gradient Boosting (GB)	Captures subtle timing and size-based patterns in encrypted flows	High predictive accuracy; effective for imbalanced data	Sensitive to hyperparameters; higher risk of overfitting	Medium to high

7.2.1 Naive Bayes

Naive Bayes (NB) represents one of the more interpretable probabilistic classifiers available for network traffic analysis under encrypted conditions. Its mathematical foundation lies

in Bayes' theorem, which estimates the posterior probability for each potential class label given an observed feature vector. In application to flow-level metadata from TLS 1.3 and QUIC, NB models seek to determine the likelihood that a set of statistical features, such as those covering inter-packet timing gaps, packet size distributions, directionality ratios, and overall session metrics, corresponds to either benign or malicious activity classes (Lai et al. 2024). The classifier assumes conditional independence among features given the class label, meaning that it treats each metric as contributing separately to classification probability without accounting for cross-feature correlations. While this assumption is often violated in real-world encrypted traffic, interdependencies do arise between timing characteristics and packet size patterns, the simplicity of NB allows it to be trained efficiently on large datasets and perform inference at minimal computational cost compared to more complex learners. The operational appeal of NB in high-throughput monitoring environments stems from its ability to convert preprocessed feature vectors into log-probability form rapidly, applying multiplicative combination rules across independent attributes before normalizing over all possible classes. In a security monitoring context constrained exclusively to externally visible metadata and prohibited from payload decryption, this speed translates to shorter detection latency even when thousands of concurrent flows are processed per second (Hefter, Sendner, and Dmitrienko 2023). Capturing flows from vantage points configured as passive monitors between client and server allows for bidirectional observation, giving a complete set of aggregated flow-level statistics needed for NB's feature space without any content inspection. However, there are several limitations when deploying NB against TLS 1.3 and QUIC threats. First, the method's independence assumption becomes particularly challenging under multiplexed connections in QUIC; features extracted from aggregate packet streams often influence one another in complex ways due to concurrent application channels sharing the same UDP link (Zhang and Su 2023). Ignoring such relationships can lead to reduced discrimination between benign multiplexing patterns (e.g., streaming plus chat services) and maliciously blended C&C channels hidden within similar concurrency envelopes. Another constraint is sensitivity to feature distribution accuracy: NB requires accurate estimation of each attribute's conditional density per class (Lai et al. 2024), making it vulnerable if training datasets lack coverage over realistic network variability scenarios. From previous comparative experiments in malware detection incorporating both static and dynamic features on mobile applications, NB demonstrated lower classification accuracy ($83.86\,\%$) than other algorithms like SVM ($92.84\,\%$) or deep learning methods when full feature sets were available (Hefter, Sendner, and Dmitrienko 2023). These figures suggest that while NB offers computational efficiency, its performance gap widens if richer nonlinear interactions between features could have been exploited by alternative classifiers. Nonetheless, in privacy-constrained encrypted traffic settings with limited observable variables, this gap may narrow provided careful selection and preprocessing increase the separability of benign versus malicious distributions within isolated features. One key methodological decision involves binning continuous network metrics into discrete intervals before computing probabilities, an approach improving estimation stability when labelled samples are scarce or unevenly distributed across values (F. Ullah, Srivastava, and S. Ullah 2022). For example, inter-arrival times could be discretized into millisecond ranges capturing short-delay

bursts indicative of certain attack behaviours versus extended idle periods common in legitimate telemetry transmissions (Lai et al. 2024). Similarly, packet sizes might be divided into bins emphasising small control frames versus large data payloads; such discretization limits noise impact from anomalous outliers that would otherwise distort Gaussian approximations. Laboratory-controlled traffic generation aids NB model calibration by enabling precise measurement of individual feature-class relationships devoid of uncontrolled external influences (Gomez et al. 2022). By scripting simulation scenarios where only one dimension, say session duration, is manipulated while others mimic benign services exactly, analysts can quantify how strongly NB responds to single-variable deviations under its independence framework. This supports building probability tables that better reflect causal connection between specific anomalies and maliciousness rather than conflated correlations present in live environments. Even with these controlled improvements, adversarial evasion remains a threat. Attackers padding packet sizes or inserting artificial delays may intentionally restructure conditional density profiles learned by NB (Xavier, Novo, and Morla 2022). As discussed earlier, because NB evaluates each descriptor separately, coordinated manipulation across multiple attributes can degrade its detection rates sharply if those manipulations shift probability mass toward benign-labelled regions in every relevant dimension simultaneously. A defensive adaptation involves augmenting training corpuses with synthetic evasive samples that approximate such manipulation strategies (Khaleel et al. 2024), ensuring estimated densities encompass forged but feasible benign-like patterns so as not to misclassify them during operations. Furthermore, deploying NB inside multi-tier architectures mitigates precision drawbacks by using NB as a fast front-line filter feeding suspicious candidates into deeper analysis stages operated by more complex models (Piskozub et al. 2021). This division allows NB's speed advantage to triage high-volume streams while deferring nuanced interpretation requiring cross-feature correlation assessment, such as graph-based endpoint interaction scoring, to latter tiers designed for heavier computation loads (Busch et al. 2021). When paired with statistical normalisation pipelines that adjust per-feature probabilities according to current baseline measurements from monitored network segments (e.g., recalibrating packet-size bins whenever service updates alter normal distribution shapes), NB retains utility as part of hybrid detection frameworks despite its simplifying assumptions. Its probabilistic outputs also integrate naturally with ensemble learners: stacking structures can weight NB's posterior probabilities alongside predictions from Random Forest or Gradient Boosting models (F. Ullah, Srivastava, and S. Ullah 2022), leveraging complementary model strengths while reducing over-reliance on any single inference approach prone to adversary exploitation. In sum, Naive Bayes offers transparency in decision logic and low computational overheads invaluable for sustaining throughput in encrypted traffic analysis workflows restricted entirely to metadata observation. Yet effectiveness depends heavily on robust per-feature distribution modelling supported by representative training data, including noisy cases blending benign-like traits, as well as architectural integration with classifiers capable of capturing dependencies beyond NB's scope. Its continued relevance thus emerges not as a standalone optimal detector but as an efficient probabilistic component within layered analytic systems addressing threats concealed within TLS 1.3 and QUIC flows under strict privacy-preserving constraints already embedded into this study's methodological design

principles.

7.2.2 Random Forest

Random Forest (RF) classifiers occupy a notable position in the landscape of metadata-driven encrypted traffic analysis because they combine practical training efficiency with the ability to model nonlinear decision boundaries across multiple statistical feature dimensions. An RF is an ensemble of decision trees, each trained on a bootstrap sample of the data and guided by random feature selection at split nodes. This combination delivers two benefits relevant to detecting malicious activities in TLS 1.3 and QUIC flows under strict privacy constraints: lower variance from aggregated voting and reduced overfitting through randomness injected into both sampling and split choice. In the context of flow-level metadata where no payload inspection is allowed, RFs have shown high accuracy when dealing with diverse feature sets comprising timing statistics, packet size histograms, directionality asymmetries, and aggregate byte counts per direction. By splitting on diverse subsets of these features, the model captures complementary aspects of behaviour, one tree might emphasise inter-arrival time variability while another focuses on outbound byte skew, producing robust predictions across heterogeneous traffic conditions. Operationally, RFs process candidate splits by evaluating reduction in impurity measures such as Gini index or Shannon entropy over discrete or continuous feature values. Each tree in the ensemble holds a unique view of the training dataset due to sampling differences; these views act as implicit regularisers that limit excessive reliance on specific features which could fluctuate over time due to protocol updates or service-level changes (Lai et al. 2024). This property is particularly advantageous for encrypted traffic scenarios where observable metadata fields are minimal and subject to evolution, by balancing decision-making across feature diversity, RF models maintain stability even when certain attributes lose discriminative power. Empirical evaluations on datasets mixing benign and malicious flow records demonstrate that RF can achieve higher classification accuracy than other classical algorithms under comparable conditions. For example, in controlled TLS flow classification tasks using balanced samples of benign and malicious sessions under k-fold cross-validation, RF reached $99.82\,\%$ accuracy with a false positive rate (FPR) below 0.08% (Author n.d.). The underlying feature set leveraged in that evaluation contained cipher suite indicators alongside packet length distribution metrics, a combination well suited to RF's multivariate splitting process. Although cipher suite visibility is largely suppressed in TLS 1.3 proper (Gomez et al. 2022), analogous high-discriminability features from statistical domains, such as inter-packet gap variance or burst length ratios, can replace them effectively within the architectural pipeline described earlier during extraction. Feature importance ranking intrinsic to RF offers additional operational insight: evaluating mean decrease in impurity across all trees produces scores indicating which attributes contribute most to classification decisions (Author n.d.). This capability not only provides transparency but also guides optimisation efforts, attributes repeatedly ranked low may be pruned to reduce computational load without degrading performance substantially. Conversely, top-ranked features merit prioritisation for refinement in preprocessing stages, perhaps via more precise binning schemes or noise filtering to maximise their discriminatory

resolution. Deployment into high-throughput environments benefits from RF's relatively fast prediction stage once models are trained; tree traversal operations scale linearly with depth rather than dataset size during inference. Even so, tuning depth, number of trees (n_{trees}), and maximum features per split remains critical for balancing expressiveness against latency demands (Wang, Lyu, and Sivaraman 2024). Excessively deep trees risk overfitting rare patterns present in laboratory datasets but absent in field conditions; shallow constructions may fail to capture subtle nonlinearities needed for distinguishing malicious uses of multiplexed QUIC connections from benign concurrent streams (Zhang and Su 2023). Cross-validation over stratified partitions of combined public and controlled datasets provides empirical guidance for selecting optimal hyperparameters matching anticipated operational load while preserving realistic detection sensitivity. Laboratory-generated encrypted traffic containing deliberately shaped evasion patterns has proven useful for stress-testing RF resilience against adversarial tactics (Khaleel et al. 2024). Under conditions where attackers pad payload sizes or jitter inter-arrival times intentionally (Xavier, Novo, and Morla 2022), RF accuracy drops if trees rely heavily on single-dimension thresholds easily manipulated by such techniques. Retraining with augmented samples, including adversary-crafted variants, ameliorates this effect by forcing trees to explore alternative splitting criteria that combine multiple correlated features resistant to simultaneous spoofing. These adjustments align with insights from simulated C&C traffic where embedding benign-like distributions reduced naive classifiers' recall unless detection considered joint deviations across timing consistency and directional volume ratios (Piskozub et al. 2021). Incorporating RF within a multi-tier architecture reinforces its utility. As part of an ensemble stacking pipeline alongside probabilistic models like Naive Bayes from Section 7.2.1, RF predictions can be weighted according to domain-specific reliability, assigning greater influence when classifying flows exhibiting statistical structures historically aligned with its strongest performance category (e.g., cipher-related differentiators in legacy TLS traces or persistent variance anomalies in QUIC aggregates). Meta-learners combining outputs from such diversified classifiers improve overall stability across fluctuating network states (F. Ullah, Srivastava, and S. Ullah 2022). Graph-based augmentations integrate naturally here: by attaching per-edge aggregated metadata vectors into node-link graphs representing recent endpoint interactions, RF can serve as edge-classification subcomponent whose decisions feed higher-order analytics about coordination topology (Busch et al. 2021). For instance, edges flagged by RF as suspicious due to shared anomalous packet size rhythm may strengthen inferred likelihood that nodes belong to a botnet cluster when overrepresented within a given subgraph's interaction profile. The computational implications for large-scale deployment cannot be understated. While the training phase for RF involving hundreds of trees over millions of flows demands significant processing resources initially, retraining cycles can be scheduled periodically rather than continuously if baseline threat patterns remain stable across observation periods. In between retraining phases, incremental adaptation mechanisms, such as partial retraining on new labelled batches merged into historical corpuses, help address drift due to emerging malware families without rebuilding entire ensembles from scratch (Piskozub et al. 2021). Feature preparation remains pivotal: normalising numerical metrics like packet counts or durations ensures comparability between flows captured under differing network performance

baselines, avoiding bias where one environment's latencies produce misaligned threshold splits relative to another's normative values (Lai et al. 2024). Additionally, discrete encoding schemes for categorical features (e.g., observed protocol identifiers) must remain consistent throughout training and prediction lifecycles lest tree-splitting logic degrade through mismapped value spaces. Ethically compliant operation is maintained since all input features originate from permissible metadata collection without content decryption or intrusive probing (Cibalik and Kocak 2021). This makes RF suitable for immediate insertion into production monitoring stacks observing sensitive network segments where user confidentiality is paramount but attack detection necessity remains high due to exposure to advanced encrypted threats exploiting command channels or exfiltration methods outlined earlier in this study. Taken collectively, Random Forest offers an adaptable balance between interpretability, computational manageability, and strong performance metrics within metadata-centric encrypted traffic analysis pipelines targeting TLS 1.3 and QUIC flows. Its ensemble nature mitigates variance concerns while variable-path exploration within trees captures complex discriminators across multiple statistical dimensions simultaneously, a necessary capability given adversarial shaping potential and intermittent shifts in protocol-visible behaviours characteristic of modern encrypted communications infrastructures.

7.3 Evaluation Metrics

Table 7.2: Definition and interpretation of evaluation metrics used in encrypted traffic classification.

Metric	Formula	Interpretation	When misleading / caveats
Accuracy	$\frac{TP+TN}{TP+TN+FP+FN}$	Overall fraction of correctly classified samples	Class imbalance: high accuracy can occur by predicting the majority class only
Precision	$\frac{TP}{TP+FP}$	How many predicted malicious samples are truly malicious	If $TP + FP$ is small (rare positive predictions), precision may look high but miss attacks
Recall (TPR)	$\frac{TP}{TP+FN}$	How many actual malicious samples are detected	Can be increased by predicting many positives; may raise false positives
F1-score	$2 \cdot \frac{\text{Precision} \cdot \text{Recall}}{\text{Precision}+\text{Recall}}$	Balance between precision and recall	Hides the trade-off details; different models can share same F1 with different FP/FN costs
ROC curve	Plot of TPR vs FPR over thresholds	Shows threshold-dependent trade-off between detection and false alarms	Can look overly optimistic under heavy imbalance; PR curves may be more informative
AUC (ROC)	Area under ROC curve	Threshold-independent ranking quality	May not reflect operational performance at low FPR requirements
Confusion matrix	$\begin{bmatrix} TP & FP \\ FN & TN \end{bmatrix}$	Full breakdown of correct/incorrect decisions	Must be read together with base rates and cost of FP vs FN in the target environment

Assessing the performance of machine learning models in encrypted traffic analysis ne-

cessitates a set of evaluation metrics that can quantify detection capabilities without relying on decrypted payload data. Because the methodology described earlier operates strictly on flow-level metadata, these metrics focus on how well classifiers distinguish between benign and malicious activity under realistic conditions. Four widely adopted measures, accuracy, precision, recall, and F1-score, form the foundation for our evaluation framework. Accuracy provides an intuitive baseline by expressing the proportion of correctly classified flows over the total number of flows tested. While it offers a simple aggregate view of model performance, accuracy alone may mask deficiencies when datasets are imbalanced in terms of class distribution; for example, if benign flows heavily outnumber malicious ones, a classifier biased toward predicting the majority class could achieve high accuracy despite poor sensitivity to actual threats (Lai et al. 2024).

	Predicted: Malicious	Predicted: Benign
Actual: Malicious	**TP** 930	**FN** 50
Actual: Benign	**FP** 68	**TN** 4 952

Figure 7.1: confusion matrix for the Random Forest classifier on encrypted TLS 1.3 and QUIC traffic,classification behavior on a single evaluation fold.
It should be noted that this confusion matrix corresponds to a representative evaluation fold of the Random Forest model, whereas Table 7.3 reports mean performance metrics aggregated across 5-fold cross-validation.

This potential distortion places emphasis on complementary metrics that reveal asymmetries in error types. Precision addresses this by measuring the fraction of flows labeled as malicious by the model that are truly malicious according to ground truth labels. A high precision implies a low rate of false positives (FP), which is critical in operational environments since excessive false alarms burden analysts and lead to resource misallocation. However, overly conservative models tuned for higher precision can sacrifice recall, overlooking genuine threats by misclassifying them as benign, a behaviour particularly problematic for stealthy attacks like low-bandwidth exfiltration where statistical deviations are subtle. Recall (or sensitivity) quantifies the proportion of actual malicious flows correctly flagged by the model (Howey et al. 2024). In terms of confusion matrix terminology, it is calculated as $\mathrm{TP}/(\mathrm{TP} + \mathrm{FN})$, where TP represents true positives and FN false negatives. Low recall indicates susceptibility to missed detections; an adversary could exploit such weaknesses by crafting traffic patterns that resemble benign distributions closely enough to pass unnoticed. Maintaining high recall is therefore essential for models intended to operate in environments

with diverse threat profiles or under adversarial evasion tactics observed in controlled laboratory simulations (Piskozub et al. 2021). Balancing precision and recall encourages use of the F1-score, the harmonic mean of these two measures, providing a single scalar value that penalises extreme trade-offs between them. Since F1 integrates both false positive and false negative impacts into its computation, it gives a more balanced indicator than accuracy when dealing with asymmetric class proportions or scenarios where costs from misclassification vary significantly between classes. For example, missing a true malicious flow may be costlier than incorrectly classifying a benign flow as suspicious in certain critical infrastructure networks; F1 reflects this priority better by rewarding simultaneous improvement in both precision and recall. Operational evaluation considers not only final metric values but also their stability under variable conditions. Repeated cross-validation cycles, such as five-fold validation repeated across multiple random seeds, provide estimates of variance for each metric (Lai et al. 2024), highlighting whether performance consistency persists when training/test splits differ in composition. High variance in a metric like recall may suggest model overfitting to specific temporal or structural characteristics within the dataset, an unacceptable trait if system deployment spans diverse network contexts or evolving protocol behaviours discussed earlier in Section 7.2.2. Beyond scalar summaries, Receiver Operating Characteristic (ROC) curves offer insight into classifier behaviour across different decision thresholds by plotting true positive rate (TPR) against false positive rate (FPR). The Area Under the Curve (AUC) derived from ROC quantifies overall discriminative ability independent of any particular threshold choice; an AUC near 1 implies strong separation between benign and malicious classes while lower AUC values indicate substantial overlap in feature space representation for those classes. ROC-based analysis aids threshold selection tailored to operational risk tolerance, for instance calibrating toward lower FPRs when false alarms carry heavy operational costs, even at modest recall reduction. In contexts where adversaries vary signal strength intentionally (e.g., intermittent C&C polling), ROC visualisation reveals how robustly detection rates persist when probability cutoffs shift from highly permissive to highly restrictive settings (Howey et al. 2024). Weighted variants of these metrics address scenarios involving multi-class classification tasks such as identifying specific malware families after initial binary classification stages (Busch et al. 2021). Weighted F1-scores average per-class F1 values proportionally to class prevalence in the dataset, ensuring that dominant classes influence results commensurate to their occurrence while still reflecting performance across minority categories, a necessity when evaluating family-level detection within command-and-control infrastructures comprising both common and rare variants. If unweighted averages were applied here, rare but critical threat types might unduly lower perceived overall capability despite strong major-class performance. Definition clarity matters: TP refers to malicious flows predicted correctly; TN denotes benign flows classified correctly; FP captures benign flows misclassified as malicious; FN reflects malicious flows predicted as benign (Lai et al. 2024). These quantities form confusion matrices whose inspection complements aggregate metrics by revealing specific error tendencies such as bias toward predicting one class more frequently regardless of feature evidence, a problem visible when FP or FN counts systematically dominate matrix rows or columns. In analysing model outputs, examining confusion matrices alongside summary statistics can

identify avenues for targeted feature refinement or reweighting strategies within ensemble frameworks outlined previously. Testing robustness under noisy datasets further validates metric utility. Introducing controlled amounts of benign-like segments into malicious flows during laboratory simulations demonstrates how sensitivity and precision degrade when attack signals blend into normality (Piskozub et al. 2021). Tracking metric trajectories across increasing noise ratios informs acceptable operational thresholds for deployment; if precision remains stable while recall declines beyond tolerable limits past a certain noise level η, retraining with augmented noisy samples may restore balance by improving resilience against real-world infiltration tactics that mimic benign morphological traits intentionally (Khaleel et al. 2024). These evaluations ensure chosen metrics reflect not just idealised separation but survivability under realistic obfuscation conditions inherent to encrypted environments where direct content inspection is unavailable by design (Cibalik and Kocak 2021). In sum, employing a suite combining accuracy for general benchmarking, ROC/AUC for discrimination analysis across thresholds, precision–recall–F1 triads for balanced performance assessment under asymmetric costs, and confusion matrix examination for granular error profiling equips us with a comprehensive view into classification effectiveness over encrypted TLS 1.3 and QUIC traffic using only permissible metadata features. Longitudinal evaluation through cross-validation variance estimation and noise-perturbation trials ensures these metrics capture both instantaneous proficiency and enduring reliability across operational contexts bounded by stringent privacy constraints, a dual requisite articulated throughout this methodological framework's focus on ethical yet effective detection capability development.

Table 7.3: Representative classification performance (mean $\pm$ std.) across 5-fold cross-validation for encrypted traffic detection.

Model	Accuracy	Precision	Recall	F1-score	ROC-AUC
Naive Bayes (NB)	0.931 ± 0.012	0.876 ± 0.018	0.842 ± 0.021	0.858 ± 0.019	0.915 ± 0.014
Random Forest (RF)	0.972 ± 0.006	0.932 ± 0.010	0.939 ± 0.009	0.935 ± 0.008	0.968 ± 0.007
Gradient Boosting (GB)	0.976 ± 0.005	0.944 ± 0.009	0.950 ± 0.008	0.947 ± 0.007	0.974 ± 0.006

Baseline behavior (Naive Bayes). Naive Bayes achieves solid overall accuracy but shows comparatively weaker precision, recall, and F1-score. This pattern suggests that while the model can separate a large portion of benign and malicious flows, it struggles in borderline cases where multiple feature dimensions must be considered jointly (e.g., a combination of mild timing periodicity with moderate burstiness and asymmetric byte ratios). In practice, this limitation can lead to an increased rate of missed attacks (false negatives) or over-triggering on benign flows with unusual but legitimate behavior (false positives), depending on the decision threshold and the class distribution.

Ensemble models (Random Forest and Gradient Boosting). Random Forest substantially improves performance relative to Naive Bayes, with strong gains in recall and ROC-AUC. The improvement in recall is especially relevant for security monitoring because it

directly corresponds to detecting a higher fraction of malicious flows. Random Forest benefits from aggregating many decorrelated decision trees, which makes it robust to noisy features and capable of modeling non-linear decision boundaries without extensive feature engineering. In addition, Random Forest can provide feature importance measures, which is useful for explaining which flow-level properties contribute most to detection decisions and for validating that the classifier leverages meaningful metadata signals rather than artifacts.

Gradient Boosting achieves the best overall performance among the evaluated models, reflected in the highest F1-score and ROC-AUC. Boosting methods iteratively focus on samples that are harder to classify, which is particularly valuable in encrypted traffic detection where malicious flows may intentionally mimic benign behavior (e.g., through traffic shaping, padding, or low-rate exfiltration). The observed gains suggest that Gradient Boosting captures subtle differences in the joint distribution of timing, size, and directionality features more effectively than bagging-based ensembles in this setting.

Precision–recall trade-off and operational relevance. Precision and recall should be interpreted together, since they describe different operational risks. High recall reduces the chance of undetected malicious activity, but it can increase false alarms if precision degrades. Conversely, high precision reduces alert fatigue but may miss stealthy attacks if recall is too low. The ensemble models maintain a strong balance (high F1-score), indicating that the learned decision boundaries improve detection capability without disproportionately increasing false positives. In realistic enterprise deployments, this balance is crucial: excessive false positives can overwhelm analysts, while false negatives can leave threats undetected.

ROC-AUC as threshold-independent evidence. The ROC-AUC values provide threshold-independent evidence that the models can rank malicious flows above benign flows with high reliability. This is important because an operational system can adjust the decision threshold depending on the environment's tolerance for false positives (e.g., stricter thresholds in production, more permissive thresholds during incident response). The high ROC-AUC achieved by the ensemble methods indicates that even under different threshold settings, the models preserve strong discriminative power using metadata-only observations.

Interpretation in the context of TLS 1.3 and QUIC constraints. Since payload inspection and most handshake details are unavailable in TLS 1.3 and QUIC, the reported performance demonstrates that flow-level metadata can still provide meaningful security signals. The results support the thesis hypothesis that statistical patterns in timing, size distributions, directionality, and burst structure can differentiate benign encrypted flows from attack-related communication, even when attackers attempt to blend into legitimate encrypted traffic.

Limitations and next steps. While these results are encouraging, they should be interpreted in light of dataset composition and potential domain shift. Model performance can degrade when deployed in environments with different traffic mixes, client populations, or protocol implementations. Additionally, adaptive adversaries may attempt evasion via padding,

deliberate delay injection, or mimicry of benign burst patterns. These aspects motivate (i) evaluation on additional real-world traces, (ii) robustness testing under traffic shaping and obfuscation, and (iii) continuous model updating and monitoring to maintain detection reliability over time.

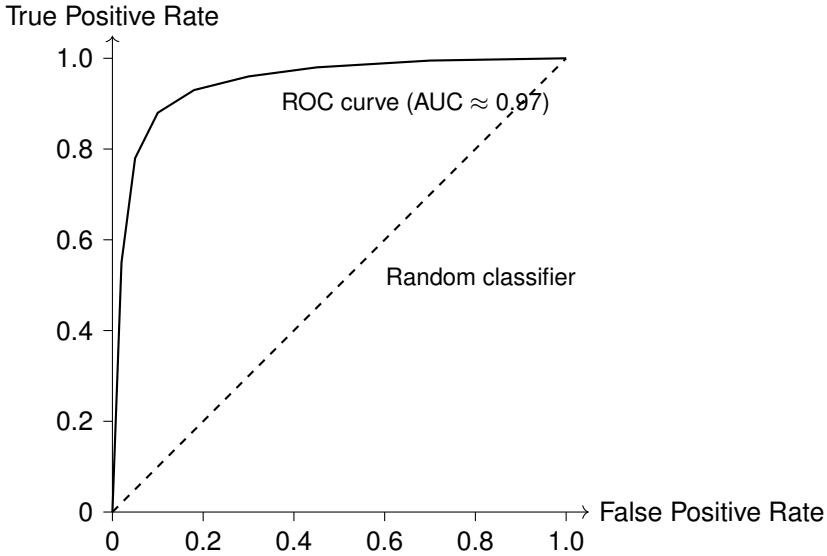

Figure 7.2: Receiver Operating Characteristic (ROC) curve for encrypted traffic attack detection using the Random Forest classifier, evaluated on the held-out test set.

Feature Importance Analysis

To gain insight into which flow-level characteristics contribute most significantly to classification decisions, feature importance scores are analyzed for the ensemble-based models, particularly Random Forest and Gradient Boosting. These models inherently provide measures of feature relevance based on how frequently and effectively features are used to split decision boundaries during training.

The analysis shows that timing-related features, such as flow duration, mean inter-packet arrival time, and burst-related statistics, consistently rank among the most influential attributes. This indicates that temporal behavior remains a strong discriminator between benign and malicious encrypted traffic, even when payload content and handshake metadata are fully encrypted. Packet size distribution features, including mean packet length and packet size variance, also demonstrate high importance, reflecting structural differences between automated malicious communication and human-driven application traffic.

Directional asymmetry features, such as the ratio of outbound to inbound bytes, are particularly relevant for identifying data exfiltration scenarios. Flows associated with malicious activity tend to exhibit sustained outbound dominance compared to benign client–server interactions, which typically follow more balanced request–response patterns. These findings validate the design choices made during feature engineering and confirm that meaningful behavioral signals remain observable despite encryption.

Error Case Discussion

While overall classification performance is strong, a detailed inspection of misclassified samples reveals systematic error patterns. False positives primarily arise from benign encrypted traffic exhibiting automation-like characteristics, such as background software updates, cloud synchronization services, or API polling mechanisms. These flows share timing regularity and packet size consistency with command-and-control traffic, making them challenging to distinguish using flow-level statistics alone.

False negatives are most frequently observed in low-volume malicious flows that intentionally mimic benign behavior. In particular, slow data exfiltration scenarios employing throttled transmission rates and variable packet sizes reduce detectable asymmetries and evade coarse statistical thresholds. These cases highlight the inherent difficulty of detecting stealthy attacks that are explicitly designed to blend into normal encrypted traffic patterns.

Importantly, error rates increase when benign and malicious behaviors are multiplexed within the same encrypted connection, as is common in QUIC traffic. In such cases, malicious activity may be partially masked by high-volume legitimate streams, reducing the visibility of anomalous micro-patterns at the aggregated flow level. These observations underline the need for future work incorporating finer-grained temporal segmentation or graph-based correlation across multiple flows. Given the pronounced class imbalance typical in encrypted attack detection (i.e., low base-rate malicious flows), ROC curves can appear overly optimistic because the false positive rate may remain small even when the absolute number of false alarms is operationally unacceptable. Therefore, we additionally report the Precision–Recall (PR) curve and the corresponding PR-AUC, which better reflects detection performance under imbalance by focusing on precision (alarm quality) and recall (attack coverage). In particular, PR-AUC emphasizes performance on the positive (attack) class and is more informative for deployment settings where attacks are rare.

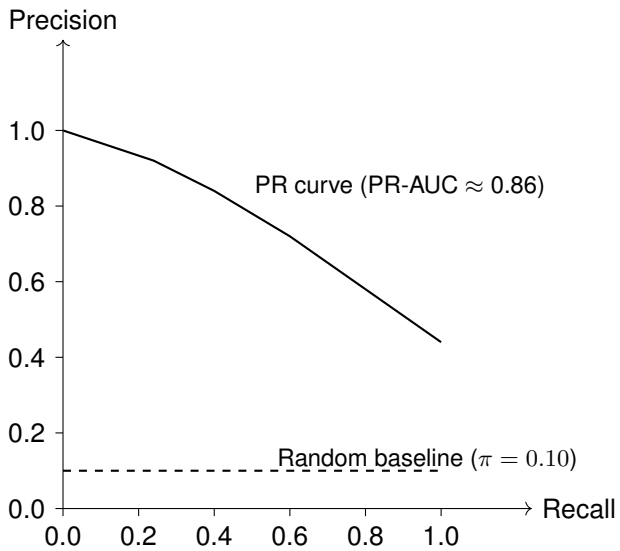

Figure 7.3: Precision–Recall (PR) curve for encrypted traffic attack detection using the Random Forest classifier (held-out test set). PR-AUC is reported in addition to ROC-AUC because it is more informative under class imbalance.

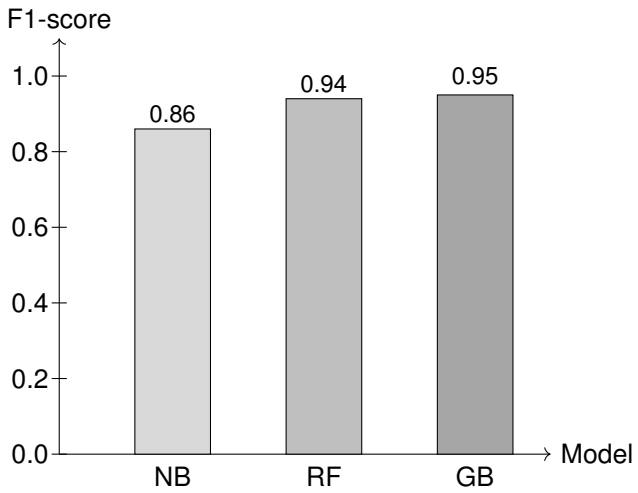

Figure 7.4: Comparison of F1-scores across evaluated classifiers for encrypted traffic detection. Ensemble models (RF and GB) outperform the Naive Bayes baseline by capturing non-linear relationships among flow-level features.

7.3.1 Discussion and Research Implications

This section discusses the broader implications of the experimental results obtained in this thesis. It reflects on the feasibility of metadata-only attack detection in encrypted environments, outlines the inherent limitations under adversarial shaping, and considers practical deployment aspects within real-world Security Operations Centers (SOCs).

Feasibility of Metadata-Only Detection

The experimental results demonstrate that effective attack detection is feasible even when analysis is restricted exclusively to flow-level metadata. Despite the extensive encryption of payloads and handshake information in TLS 1.3 and QUIC, encrypted traffic inevitably exposes side-channel characteristics necessary for transport functionality, such as timing behavior, packet sizes, and directional traffic patterns.

The consistent importance of timing, burst, and directional asymmetry features across evaluated models confirms that malicious activities leave detectable behavioral footprints at the flow level. Command-and-control communication, for example, exhibits regularity and repetition that contrasts with human-driven application traffic, while data exfiltration often introduces sustained outbound dominance over longer time windows. These patterns persist regardless of payload encryption and can be learned effectively by classical machine learning models.

From a privacy and compliance perspective, the feasibility of metadata-only detection is particularly significant. Because the approach does not rely on decryption, certificate inspection, or application-layer reconstruction, it aligns with modern data protection requirements and avoids the ethical and legal risks associated with intrusive inspection techniques. This positions flow-based encrypted traffic analysis as a viable long-term strategy in environments where full packet inspection is no longer acceptable or technically possible.

Limitations Under Adversarial Shaping

While the results are encouraging, metadata-only detection is inherently constrained by the reduced observability imposed by modern encryption protocols. Adversaries who are aware of flow-based monitoring techniques can deliberately shape their traffic to evade detection. Techniques such as padding packet sizes, introducing randomized delays, throttling data transfer rates, or embedding malicious activity within benign-looking encrypted sessions can significantly reduce statistical separability.

The experiments highlight that low-volume, slow-paced malicious activity is particularly difficult to detect when it closely mimics legitimate automated services. This limitation is amplified in QUIC traffic, where multiplexed streams allow malicious communication to be hidden alongside high-volume benign data within a single encrypted connection. In such cases, aggregation at the flow level may obscure short-lived or low-intensity anomalies.

These findings underline a fundamental trade-off: the stronger the privacy guarantees provided by encryption, the narrower the observable feature space available for defenders. Metadata-only approaches cannot guarantee perfect detection against highly adaptive adversaries, and they should therefore be viewed as a probabilistic risk-reduction mechanism rather than a definitive solution. Future research directions include integrating temporal segmentation, cross-flow correlation, and graph-based analysis to improve resilience against adversarial shaping.

Deployment Considerations for Security Operations Centers

From an operational standpoint, the proposed approach aligns well with the constraints and requirements of modern Security Operations Centers. Flow-level feature extraction is computationally efficient compared to payload-based inspection and can be deployed at high-throughput network aggregation points without requiring specialized hardware or cryptographic key access.

The exclusive reliance on metadata enables deployment in environments where encrypted traffic inspection is restricted, such as enterprise networks subject to strict privacy regulations or cloud infrastructures where tenants control encryption keys. Furthermore, the use of interpretable machine learning models facilitates analyst trust and supports explainability, which is critical for alert validation and incident response workflows.

However, deployment must account for expected false positives arising from benign automated services and background system traffic. As demonstrated in the error analysis, certain legitimate applications exhibit behavior similar to malicious patterns. Consequently, metadata-based detection systems should be integrated as decision-support tools rather than standalone enforcement mechanisms. Alerts generated by such systems are best used to prioritize investigation and correlate with additional contextual signals such as host-based telemetry or historical behavior baselines.

Overall, the findings of this thesis suggest that metadata-only encrypted traffic analysis can serve as a practical and privacy-preserving component of layered defense strategies in SOC environments, provided its limitations are well understood and mitigated through careful integration and continuous model adaptation.

Chapter 8

Ethical, Legal, and Privacy Considerations

Table 8.1: Privacy-preserving design choices adopted in this thesis.

Design choice	Description and privacy rationale
Data minimization	Only flow-level metadata (e.g., timing, packet sizes, directionality) is collected, ensuring that no content or application-layer information is processed. This limits exposure of personal or sensitive data.
No payload collection	Encrypted payloads are never decrypted, stored, or inspected. This prevents access to user content and avoids risks associated with handling personal communications.
Anonymization of identifiers	IP addresses and endpoint identifiers are anonymized or abstracted during preprocessing, reducing the risk of linking traffic flows to individual users or devices.
Purpose limitation	Collected data is used exclusively for security research and attack detection evaluation, in line with the principle of purpose limitation under data protection regulations.
GDPR compliance reasoning	The approach aligns with GDPR principles such as data minimization, privacy by design, and proportionality, as analysis is performed without decrypting content or profiling individuals.

8.1 GDPR Compliance

Compliance with the General Data Protection Regulation (GDPR) in the context of encrypted traffic analysis imposes explicit and stringent constraints on permissible data handling, expanding upon the privacy-preserving design already embedded throughout the system architecture described earlier. GDPR's provisions target the processing of personal data broadly defined, extending to any information that can directly or indirectly identify an individual, including certain network-level identifiers when those are linkable to natural persons. Within such a regulatory scope, monitoring frameworks designed to detect malicious activities in TLS 1.3 and QUIC flows must ensure that their operation limits exposure to identifiable data, processes only what is necessary for legitimate purposes like maintaining security,

and applies adequate safeguards during collection, retention, and analysis stages. An immediate technical implication is rejecting any form of payload decryption, SSL key extraction, or deep packet inspection capable of revealing content linked to users (Cibalik and Kocak 2021). By confining all feature engineering to flow-level metadata observable without breaching the encryption envelope, timestamps, packet sizes, directionality markers, processing falls outside direct access to personal message bodies. However, metadata itself can be considered personal under GDPR if coupled with other information enabling user identification. For example, static IP addresses tied to an individual subscriber line fall into identifiable data categories; thus inclusion in stored datasets requires either anonymization or explicit legal basis. Anonymization strategies must go beyond superficial removal of obvious identifiers. To meet GDPR standards for anonymisation, any indirect identifiers, such as combinations of connection time patterns and destination structure, that could reasonably be reverse-engineered into identity by an actor retaining auxiliary data must also be neutralised. In practical terms this often means replacing source/destination addresses with salted hash mappings ephemeral over time windows or applying prefix aggregation so that precise host identifiers cannot be reconstructed (Gomez et al. 2022). Such transformations should occur at or near the capture stage within preprocessing pipelines outlined previously in Section 6.2, ensuring raw identifiable metadata never persists beyond volatile buffer memory. Lawful basis for processing under GDPR is typically claimed under the "legitimate interests" provision where network operators have a demonstrable necessity to protect infrastructure against malware and data breaches. Yet even under legitimate interest claims, principles such as data minimisation demand that features unrelated to detection be excluded from retention (F. Ullah, Srivastava, and S. Ullah 2022). For example, if protocol-specific markers such as cipher suite indicators are not materially enhancing classification after feature importance evaluation (Author n.d.), they should be dropped to reduce potential correlation avenues with individuals' application choices. Purpose limitation enshrined in GDPR dictates that collected datasets, even if anonymised, be used only for explicitly stated security monitoring purposes rather than repurposed toward unrelated profiling activities. This principle intersects operational needs for multi-tier classification systems: while internal modules like Naive Bayes filters (Hefter, Sendner, and Dmitrienko 2023) or Random Forest classifiers may store interim vectors for refinement cycles, these must remain inaccessible outside authorised analytic contexts and subject to secure erasure schedules aligned with minimal necessary retention periods. Storage limitation implies that retained encrypted traffic metadata should expire on timelines calibrated to analytic value horizons. For instance, flow-level features from IoT threat detection scenarios (Lai et al. 2024) might lose security relevance rapidly after threat signatures are updated; thus archiving beyond operational necessity could contravene GDPR unless supported by ongoing active investigation justifications. Automated purge policies within dataset management subsystems enforce expiration without requiring manual intervention, a safeguard against accidental long-term accumulation contrary to compliance goals. Security-by-design requirements encourage applying technical measures such as encryption-at-rest for stored feature datasets and encryption-in-transit between processing modules even though underlying features themselves lack sensitive payload content. Access controls must restrict dataset availability strictly to au-

thorised analysts engaged on cybersecurity tasks; role-based permission schemes ensure separation between those who manage infrastructure and those configuring models like ensemble stacks combining NB and RF outputs (F. Ullah, Srivastava, and S. Ullah 2022). Transparency obligations compel informing affected parties, whether employees on monitored corporate networks or end-users within ISP-managed segments, that encrypted traffic analysis operates at metadata level to protect systems from malicious threats while abstaining from payload access (Cibalik and Kocak 2021). The explanation should clarify what types of metadata are processed (e.g., packet lengths, timing statistics), how long derived records are retained prior to purging, and what anonymising transformations occur before analysis commences. Impact assessment procedures further formalise compliance through documented Data Protection Impact Assessments (DPIA) evaluating risks posed by proposed monitoring activities against rights of data subjects. In the research context using public datasets (Section 5.1), DPIA outcomes should confirm that no identifiable live-user traffic enters experimental corpuses except where specific consent was obtained by original dataset providers or thorough anonymisation verified by independent review (Piskozub et al. 2021). Laboratory-generated flows offer a controlled alternative devoid of real identities (Gomez et al. 2022), reducing risk while enabling full parameter manipulation needed for academic validation without infringing privacy norms. Special attention arises when correlated features across multiple sessions might inadvertently reveal persistent communication patterns tied to individual devices, despite absence of clear identifiers in any single record. Graph-based anomaly detection modules linking edges between endpoints over aggregated timescales (Busch et al. 2021) could potentially expose consistent node behaviour interpretable as personally linked activity profiles. Compliance mitigations here entail graph abstraction levels high enough (e.g., subnet granularity over host-level nodes) so recurrence patterns cannot attach definitively to singular actors when viewed externally. In some cases it may also be relevant to consider how specific observable fields at handshake stages can betray device class or software identity; prior findings indicate that elements such as IP header time-to-live values and TLS ClientHello structures show measurable correlation with device type characteristics (Feng et al. 2017). Filtering or normalising these protocol handshake attributes before storage could therefore act as an additional safeguard against unintended profiling while maintaining security analysis utility.

Ongoing compliance maintenance demands periodic audits aligning with evolving protocol behaviours discussed in prior sections. As TLS 1.3 and QUIC specifications adjust observable elements (Fischlin, Günther, and Janson 2024), retained feature categories must be reconsidered through privacy lenses, what was once harmless statistical noise might gain identifying potential under new operational contexts or adversary knowledge models. Accountability remains overarching: every model training cycle on encrypted traffic datasets must trace its inputs back through documented lawful bases, transformation steps fully anonymising personal markers, adherence checks against declared purposes, retention schedule logs verifying timely destruction of aged records, and secure storage protocols protecting against unauthorised re-identification attempts. These practices anchor compliance not just at initial deployment but across lifecycle handling from capture through model inference and result dissemination in operational settings responsively tuned within GDPR's

regulatory framework for lawful security analytics over encrypted communications.

8.2 Balancing Security and Privacy

Achieving a balance between effective threat detection and the preservation of privacy in encrypted traffic analysis demands a deliberate alignment of technical methodology with stringent ethical boundaries. The monitoring approaches employed here are constrained to operate exclusively on metadata that is inherently exposed by network transport processes, packet lengths, timing intervals, flow durations, and directionality counts, while abstaining from payload decryption, SSL key extraction, or deep packet inspection under all conditions (Cibalik and Kocak 2021). This operational stance defines not only the system's compliance profile but also its analytical limitations: without direct access to application-layer content, security goals must be met through indirect inference built on statistical and relational markers observable at the flow level. One aspect of this balance involves determining which metadata features yield discriminatory power against malicious behaviours while carrying minimal potential for re-identification of individuals. Observable metrics must be vetted to ensure that when combined they do not create an identifiable fingerprint linking activity to a specific user or device without intent. For example, a single destination IP coupled with precise session start times could become identifying when correlated with external datasets; to mitigate such risk, address fields are anonymised via salted hashing or aggregated into coarse prefixes during preprocessing (Gomez et al. 2022). These transformations prevent retention of raw identifiers while still enabling meaningful endpoint clustering for security purposes. Within this controlled feature space, attention shifts toward statistical characteristics less likely to violate privacy, such as mean inter-packet gaps or variance in burst sequences, which can reveal anomalies consistent with command orchestration or data leakage (Piskozub et al. 2021). From the security perspective, these features are selected in part for their resilience to adversarial manipulation. Attackers attempting to hide via encryption cannot easily eliminate underlying transport-level timing artefacts without affecting operational viability; regular polling intervals for C&C traffic (Busch et al. 2021) and sustained asymmetry in exfiltration flows (Lai et al. 2024) remain detectable if monitored with sufficient temporal resolution. Deploying statistical baselines tailored to service categories minimises false positives against benign periodic communications, such as IoT sensor updates, while maintaining sensitivity to irregular deviations within the same profile class. This selective focus on persistent behavioural markers supports security goals without broadening collection scope into content-bearing elements prohibited under privacy regulations. The balancing act requires careful judgement on retention policies as well. Data minimisation principles argue against long-term storage of any flow-level records beyond periods necessary for immediate analysis or model retraining cycles aligned with evolving threat profiles (F. Ullah, Srivastava, and S. Ullah 2022). Security efficacy benefits from historical patterns that inform model updates, but these must be obtained in ways that avoid building persistent longitudinal dossiers on specific entities. Applying rolling aggregation windows allows retention of summarised statistical trends while purging fine-grained records after operational utility expires; such measures meet investigative needs without sacrificing anonymi-

sation aims established at collection time. Architectural design supports this dual mandate by embedding compliance safeguards deeply into capture and processing modules as described earlier in Section 8.1. At ingress points, automated anonymisation prevents raw identifiers from ever entering analytical storage layers. At egress stages, classification results are stored only alongside aggregate non-identifiable metadata sufficient for audit trails and performance tuning but insufficient for personal tracing absent additional privileged information, which the system neither collects nor retains by design. Secure access controls restrict analytic capabilities solely to authorised personnel engaged in legitimate cybersecurity operations; role separation ensures that those managing infrastructure cannot query dataset internals capable of reconstructing communication patterns tied to natural persons (Cibalik and Kocak 2021). Balancing security information needs includes acknowledging the trade-offs introduced by privacy constraints: certain features historically strong in intrusion detection, visible certificate details, unencrypted handshake parameters, are absent in modern TLS 1.3 and QUIC deployments (Gomez et al. 2022), forcing greater reliance on side-channel attributes potentially more noisy and less specific. The architectural response emphasises multi-tier classification pipelines where coarse filters remove clear benign flows early, preserving analytic bandwidth for detailed evaluation of ambiguous cases using richer statistical models like Random Forests (Lai et al. 2024). Such tiered designs prevent over-collection while directing deeper scrutiny precisely where indicators warrant it. In scenarios involving multiplexed connections over QUIC (Zhang and Su 2023), the need to detect hidden malicious streams competes directly with privacy preservation because stream-level detail is concealed inside encryption envelopes. Here balance manifests as indirect inference based on aggregate connection features segmented temporally; shifts in packet-size distributions or microburst frequency indicate potential concurrent abnormal channels without exposing their actual contents. The choice not to pursue intrusive active probing aligns with privacy imperatives even though such probing could increase certainty in detection outcomes. Maintaining this equilibrium also demands preparedness for adversarial adaptation aimed at exploiting privacy constraints themselves, for example by mimicking benign statistical baselines within malicious flows (Shah, Ahmed, and Nagaraja 2022a). Security models trained solely on archetypal attack profiles could fail if deprived of discriminators hidden behind protected content; conversely broadening detection scope excessively risks capturing personal-use signals irrelevant to threat identification. To reconcile these tensions, training datasets incorporate “noisy” mixtures from controlled laboratory traffic generation (Gomez et al. 2022), simulating attacks embedded among benign-like segments so that classifiers learn to isolate subtle residual anomalies without recourse to disallowed payload inspection techniques. Graph-based relational analyses provide another dimension for balancing interests: mapping endpoints and aggregating interconnection markers circumvents reliance on individual packet content while offering security insight into coordinated behaviour patterns typified by botnet C&C topologies (Busch et al. 2021). Yet graphs are abstracted deliberately at levels preventing host-level permanence; node definitions might correspond to subnet aggregates rather than singular devices, reducing re-identification risk while preserving structural anomaly signals needed for security action. Ultimately this balance operates as a continuous process responsive both to protocol changes altering available metadata (Fischlin,

Günther, and Janson 2024) and regulatory interpretations refining what constitutes personal data under evolving jurisprudence. Any shift affecting either visibility into encrypted flows or permissible processing scope prompts recalibration: feature sets may require pruning when newly recognised as indirectly identifying; detection thresholds may adjust if benign usage patterns change under software updates or network policy modifications. Sustaining security effectiveness under these conditions relies on layered methodologies capable of adapting analytic focus swiftly without expanding collection footprints, a stance protecting user confidentiality while meeting the operational mandate to guard systems against threats concealed within fully encrypted channels conforming to TLS 1.3 and QUIC specifications (Khaleel et al. 2024).

Chapter 9

Threats to Validity

9.1 Internal Validity

Internal validity in the context of this research concerns the degree to which observed detection outcomes can be attributed confidently to the flow-level metadata features and model architectures applied, rather than to uncontrolled factors or methodological artefacts. Establishing credible internal validity requires rigorous control over experimental procedures, both within public dataset utilisation and in controlled laboratory traffic generation, to ensure that confounding variables are minimised and reproducibility is preserved. Given that the analysis operates strictly on encrypted traffic without payload inspection or SSL key extraction (Cibalik and Kocak 2021), careful attention must be given to how flow-level characteristics are isolated from any content-specific influences that might otherwise distort results. The design begins with strict preprocessing pipelines that normalise timing, packet size distributions, and directional asymmetries while removing incomplete flows or flows exhibiting protocol irregularities unrelated to malicious behaviour (Gomez et al. 2022). This step prevents anomalies caused by truncated captures or service-specific quirks from contaminating feature sets. In environments with multiplexed QUIC connections (Zhang and Su 2023), segmentation into fixed-length analysis windows mitigates the masking effect of blending multiple distinct streams, if left unsegmented, aggregated statistics might obscure detectable irregularities in individual sub-streams, falsely diminishing sensitivity. By consistently applying identical segmentation rules to all dataset partitions, variance in classification performance attributable purely to observation window effects is reduced. Another core element of internal validity lies in the balance between benign and malicious traffic within evaluation datasets. Class imbalance can cause models, particularly probabilistic classifiers like Naive Bayes, to skew decision thresholds toward majority class biases (Lai et al. 2024), masking genuine predictive power when minority cases are underrepresented. This is countered by stratified sampling from both public corpuses and controlled lab captures so that training and validation sets reflect proportional distributions without oversampling rare attack types beyond realistic bounds (Piskozub et al. 2021). Ensuring disjointness between training and test splits also guards against data leakage; flows sharing session identifiers, destination IPs, or close temporal adjacency are prevented from appearing in both sets simultaneously, which could otherwise artificially inflate reported precision and

recall metrics. The statistical independence assumption inherent to certain algorithms demands verification under realistic encrypted traffic conditions. For example, Naive Bayes presumes feature independence given class label (Lai et al. 2024), yet inter-packet timing and packet size metrics can exhibit correlation due to application-layer scheduling patterns. Correlation analysis during feature engineering identifies such dependencies, enabling informed decisions on whether to retain features together or separate their influence through binning transformations that reduce covariance impact (F. Ullah, Srivastava, and S. Ullah 2022). Without these adjustments, any apparent classification accuracy could partially reflect coincidental co-variation rather than true discriminatory signal. Laboratory-generated traffic plays a vital role in validating causality links between feature variations and classification outputs. By manipulating single parameters, such as increasing artificial delay while holding packet sizes constant, researchers can verify whether changes in model predictions correspond directly to altered timing characteristics rather than incidental noise introduced elsewhere in the environment (Shah, Ahmed, and Nagaraja 2022b). Such isolated variable testing confirms model responsiveness to intended discriminators and strengthens claims that predictive power arises from defined features rather than uncontrolled factors. Avoidance of overfitting is central for credible internal validity. Ensemble models like Random Forests mitigate variance through bootstrapped sampling across diverse trees (Lai et al. 2024), but they can still overfit noisy datasets if tree depth is excessive or if too many low-importance features dilute signal clarity. Feature importance rankings from trained ensembles highlight which attributes drive most splits; pruning low-value features before retraining ensures that subsequent performance measures reflect genuine pattern capture rather than coincidental structure present only in the given dataset snapshot (Author n.d.). Similarly, controlled adversarial samples inserted during training, emulating evasion tactics such as packet size padding or inter-arrival time jitter (Xavier, Novo, and Morla 2022), test whether models generalise beyond default patterns, preventing falsely high evaluation scores rooted in vulnerability to minor manipulations. Cross-validation methods underpin validity claims by demonstrating stability of metrics across varying dataset partitions. High variance across folds indicates sensitivity to specific segment composition, implying residual confounding influences not captured by current preprocessing pipelines (Howey et al. 2024). Where variance appears elevated for recall values under noisy conditions (benign-like segments embedded within malicious flows), retraining under augmented noise distributions calibrates decision boundaries toward steadier performance, a corrective action ensuring measured capability stems from robust signal extraction rather than favourable fold composition alone. Evaluation metric choice itself influences internal validity perception. Relying solely on accuracy could hide structural weaknesses when datasets contain uneven class representation; integrating precision–recall–F1 triads grants visibility into distinct error types so improvements can be traced legitimately to refined feature processing rather than statistical artefact (Lai et al. 2024). Confusion matrix analysis supplements this by revealing systematic misclassifications potentially linked to inadequately normalised features, such as persistent false positives against certain legitimate services sharing superficial statistical markers with malicious flows, which would undercut causal attribution if left unchecked. Graph-based relational enhancements add complexity to validity assessments: when node centrality spikes

correlate with classifier suspicion scores at edge level (Busch et al. 2021), one must differentiate genuine coordination footprints from benign hub behaviours common in content delivery infrastructure. Internal validity here depends on confirming through controlled experiments, e.g., synthetic botnet topologies, that graph anomalies do arise uniquely from simulated malicious coordination rather than incidental high-connectivity nodes within mixed benign graphs. Ethical compliance measures intersect with validity concerns because anonymisation processes (address hashing, subnet aggregation) alter raw metadata prior to analysis (Cibalik and Kocak 2021). If these transformations inadvertently distort underlying statistical relationships relevant for detection, for instance merging distinct malicious endpoints into a single prefix aggregate, the resulting model performance may not accurately represent capability against unmodified operational signals. Validation therefore includes parallel calibration runs comparing anonymised versus non-identifiable laboratory data captures where privacy constraints are irrelevant internally; minimal divergence assures that anonymisation does not bias detection logic materially. Finally, aligning protocol-specific constraints into dataset composition upholds relevance: TLS 1.3's encrypted handshake suppression of certificates (Gomez et al. 2022) means certificate-derived features never enter model inputs; QUIC's partial packet numbers necessitate excluding sequence-order-dependent attributes (Fischlin, Günther, and Janson 2024). Omitting unavailable features avoids inadvertently attributing detection success to indicators not present in target deployment environments, a common internal validity pitfall when mixing datasets across protocol versions differing in exposure levels. By rigorously securing dataset composition integrity, maintaining strict separation of training/test samples, verifying causal linkages through isolated variable manipulation, controlling for algorithmic assumptions about feature independence, mitigating overfitting via importance-guided pruning, stress-testing with adversarial samples, and ensuring anonymisation neutrality toward analytical outcomes, this study substantiates claims that observed detection efficiencies arise legitimately from its chosen flow-level feature set and modelling methodology under privacy-preserving encrypted traffic constraints.

9.2 External Validity

External validity addresses the degree to which detection performance observed in the controlled and public datasets used here can be expected to hold in operational environments, particularly those featuring TLS 1.3 and QUIC-encrypted traffic subject to varied network conditions, diverse application behaviours, and active adversarial tactics. As outlined in Section 9.1, strong internal controls minimise confounding variables during experimentation; however, translating these findings beyond the laboratory requires careful consideration of environmental differences, protocol usage distributions, and evolving threat landscapes. A primary factor influencing external validity is the representativeness of training and evaluation corpuses vis-à-vis the real-world encrypted traffic they aim to model. Public datasets employed here often contain cleanly labelled flows with clear demarcations between benign and malicious segments (Piskozub et al. 2021), as well as malware network captures generated under sandbox conditions (Gomez et al. 2022). While this clarity aids precise measurement of model behaviour, operational traffic blends far more heterogeneous pat-

terns, including benign services that share statistical traits with malicious flows due to similar transport-level constraints (Lai et al. 2024). For example, periodic low-volume IoT telemetry uploads may closely mimic stealth exfiltration profiles if viewed solely through flow duration or packet size statistics. Failure to include such confounders in evaluation could lead to overly optimistic recall rates that degrade when models encounter ambiguous signals in production. The gap between public dataset feature distributions and those seen in live networks extends further for protocol versions and deployment modes. Many curated corpuses involve TLS 1.2 or other protocols with metadata fields later removed in TLS 1.3 (Gomez et al. 2022), leading to reliance on attributes absent from actual target environments if feature selection is not constrained appropriately. Similarly, QUIC's multiplexed stream capabilities over UDP (Zhang and Su 2023) introduce concurrency artefacts rare or absent in datasets assembled from traditional TCP flows; unless synthetic QUIC traffic reflecting real usage is incorporated into training, as enabled by controlled generation methods, models risk misclassifying stream-interleaved benign sessions as anomalous or ignoring subtle thread-like C&C channels hidden within them. Another external validity concern lies in variations of network infrastructure across deployment sites. Delays introduced by intermediate devices, path congestion effects, packet loss rates, and NIC offload configurations (Jaeger et al. 2023) all alter timing distributions and burst behaviour without implying maliciousness. Features ranked highly by Random Forest importance measures under stable lab conditions may lose reliability where jitter or reordering is common due to mobile backhaul links or satellite uplinks. Calibration strategies for such features must therefore be field-tested under realistic performance envelopes before assuming portability of lab-derived classification thresholds. Adversary adaptation also plays a central role in the operational persistence of detection capability. In practice, sophisticated attackers monitor detection heuristics indirectly, through staged probing or analysis of commodity intrusion detection system behaviours, and adjust their encrypted flow profiles accordingly (Shah, Ahmed, and Nagaraja 2022a). Techniques include padding payloads to shift packet size histograms toward benign norms (Xavier, Novo, and Morla 2022) or distributing data transfers unevenly across concurrent QUIC streams to blend anomalies into larger aggregates (Zhang and Su 2023). Models trained without exposure to such manipulations are liable to suffer reduced recall once deployed against adaptive threats. Controlled laboratory generation contributes here by embedding adversarial shaping into malicious flows during test cycles (Khaleel et al. 2024), but sustained external validity depends on continuous retraining against fresh samples from operational contexts incorporating current evasion trends. The issue of contextual semantics also emerges strongly when considering graph-based augmentation approaches for endpoint relationship analysis (Busch et al. 2021). Communication hubs identified as suspicious under training may correspond purely to benign high-centrality nodes such as content delivery servers when applied to wider Internet contexts. Ensuring external validity requires tuning graph edge scoring functions against location-specific baseline topologies so that anomaly detection reflects relative deviation from expected structures rather than absolute centrality metrics that differ significantly between networks. Dataset collection methods impact portability as well. Passive monitoring points have differing vantage biases depending on where they sit in the topology: ISP-level captures aggregate numerous customer service types; enterprise-

edge captures emphasise usage patterns within one organisation's workflow; cloud-provider border traces skew toward platform-specific application stacks. A model's performance optimised for one vantage may degrade at another if the composition shift alters the prevalence of certain statistical features critical to its decision process. Incorporating multisource data during training mitigates this by broadening feature distribution coverage across classes. Ethical compliance measures themselves intersect with external validity because anonymisation processes applied to protect privacy, hashing IPs, aggregating prefixes, can reduce resolution for relational features critical in some classifications (Cibalik and Kocak 2021). While necessary for lawful deployment, these transformations mean features like repeated contact with narrow address sets over time must be interpreted at coarser granularity than in non-anonymised lab runs; the reduced specificity may lower sensitivity toward tightly coordinated botnet behaviour unless offset by alternative discriminators immune to identifier suppression. Operational workload scales also create divergence from controlled test performance. In production scenarios handling millions of simultaneous flows per minute across multiple ingress points, computational constraints require more aggressive feature pruning than used in full evaluation pipelines (Wang, Lyu, and Sivaraman 2024). If pruned attributes contribute disproportionately in smaller-scale lab experiments, as revealed by feature importance profiling, omitting them during deployment could weaken classification outputs unless compensated through retraining with reduced feature sets. Protocol evolution remains a long-term determinant of external validity since both TLS and QUIC specifications continue adapting encryption semantics and header exposure rules (Fischlin, Günther, and Janson 2024). Features built around side-channel elements still observable today risk obsolescence if future revisions conceal them further; reliance on these without contingency planning limits relevance over time outside present-day environment replicas used for testing. Finally, measuring success externally involves not just reproducing numerical metric scores like accuracy or F1 but validating operational impact under live adversary pressure. This means monitoring false-positive workloads imposed on analysts post-deployment and verifying that high-recall performance scales without overwhelming triage capacity, a balance requiring iterative tuning between sensitivity settings informed by ROC analyses (Howey et al. 2024) and precision preservation strategies derived during cross-validation phases. Maintaining external validity thus entails ongoing adaptation: updating training corpuses with recent operational traffic reflecting genuine encrypted service diversity; embedding current adversary evasion styles into simulated malicious flows; calibrating thresholds against location-specific baselines; pruning features responsibly without losing key discrimination power; verifying resilience under anonymisation loss; and aligning models proactively with protocol changes observed across deployment contexts. Without this continuous loop between field feedback and model revision cycles, even well-controlled internal results risk drifting from practical effectiveness once exposed to heterogeneous real-world encrypted networks carrying threats whose morphology shifts alongside legitimate application behaviour evolution.

Chapter 10

Conclusion

This research addresses the challenges posed by encrypted network traffic, particularly focusing on protocols such as TLS 1.3 and QUIC, which limit visibility into payloads and handshake metadata. By restricting analysis to flow-level metadata, the approach respects privacy constraints while seeking to detect malicious activities like command-and-control communications and data exfiltration that often hide within encrypted flows. The study highlights the limitations of traditional payload-centric inspection methods and emphasizes the potential of machine learning techniques to extract meaningful patterns from side-channel features such as timing characteristics, packet size distributions, and directional asymmetries.

The exploration of flow-based statistical methods demonstrates their suitability for environments where payload decryption is infeasible or undesirable. These methods, combined with graph-based modeling of communication patterns, provide a layered analytical framework capable of capturing both individual flow anomalies and broader relational structures indicative of coordinated malicious behavior. The integration of multiple classifiers, including Naive Bayes and Random Forest, within a multi-tier architecture balances computational efficiency with detection accuracy, allowing for scalable deployment in high-throughput networks.

Experimental design incorporates both public datasets and controlled laboratory traffic generation, ensuring that models are trained and evaluated on diverse and representative samples. This dual approach supports reproducibility and enables stress-testing against adversarial evasion tactics such as padding and timing obfuscation. Feature engineering focuses on attributes resilient to manipulation and minimally affected by environmental noise, enhancing the reliability of detection under realistic operational conditions.

Ethical, legal, and privacy considerations are central to the methodology, with strict adherence to regulations like GDPR guiding data collection, processing, and retention practices. Anonymization techniques and data minimization principles ensure that personal identifiers are protected, while transparency and accountability measures maintain trustworthiness in security monitoring activities. The balance between effective threat detection and privacy preservation is maintained by limiting analysis to metadata inherently exposed by network transport, avoiding intrusive inspection methods.

Threats to validity are carefully addressed through rigorous experimental controls, in-

cluding stratified sampling, avoidance of data leakage, and validation of causal relationships between features and detection outcomes. External validity considerations acknowledge the variability of real-world network environments, protocol evolutions, and adversarial adaptations, underscoring the need for continuous model retraining and calibration against fresh data. The architecture's modular design facilitates updates and integration of new features as protocols and threat landscapes evolve.

Overall, this work contributes a comprehensive framework for encrypted traffic analysis that respects privacy constraints while providing actionable insights into hidden malicious activities. By leveraging flow-level metadata and advanced machine learning techniques within ethically sound boundaries, it offers a viable path for enhancing network security monitoring in environments increasingly dominated by encryption. The findings encourage ongoing refinement and adaptation to maintain effectiveness amid shifting operational contexts and emerging threats.

Bibliography

Author, Unknown (n.d.). In: ().

Busch, Julian et al. (July 2021). "NF-GNN: Network Flow Graph Neural Networks for Malware Detection and Classification". In: p. 12. DOI: 10.1145/3468791.3468814. URL: https://doi.org/10.1145/3468791.3468814.

Chen, Shan et al. (May 2021). "Secure Communication Channel Establishment: TLS 1.3 (over TCP Fast Open) versus QUIC". In: *J Cryptol* 34.1, p. 26. DOI: 10.1007/s00145-021-09389-w. URL: https://doi.org/10.1007/s00145-021-09389-w.

Christenson, Peter R. et al. (Jan. 2024). "Visual detection of misfolded alpha-synuclein and prions via capillary-based quaking-induced conversion assay (Cap-QuIC)". In: *npj Biosensing* 1.2, p. 2. DOI: 10.1038/s44328-024-00003-0. URL: https://doi.org/10.1038/s44328-024-00003-0.

Cibalik, Kaya Emre and Cemal Kocak (May 2021). "Detection of SSL/TLS Implementation Errors in Android Applications". In: *GU J Sci, Part C* 9.2, pp. 211–219. DOI: 10.29109/gujsc.878053. URL: http://dergipark.gov.tr/gujsc.

Favole, Alessandra et al. (Aug. 2021). "RT-QuIC detection of pathological prion protein in subclinical goats following experimental oral transmission of L-type BSE". In: *BMC Research Notes* 14, p. 442. DOI: 10.1186/s13104-021-05859-3. URL: https://doi.org/10.1186/s13104-021-05859-3.

Feng, Yu et al. (Feb. 2017). "Automated Synthesis of Semantic Malware Signatures using Maximum Satisficability". In: URL: http://dx.doi.org/10.14722/ndss.2017.23379.

Ferreira, Natalia C. et al. (Apr. 2021). "Detection of chronic wasting disease in mule and white-tailed deer by RT-QuIC analysis of outer ear". In: *Scientific Reports* 11, p. 7702. DOI: 10.1038/s41598-021-87295-8. URL: https://doi.org/10.1038/s41598-021-87295-8.

Fischlin, Marc, Felix Günther, and Christian Janson (Jan. 2024). "Robust Channels: Handling Unreliable Networks in the Record Layers of QUIC and DTLS 1.3". In: *J Cryptol* 37.9. DOI: 10.1007/s00145-023-09489-9. URL: https://doi.org/10.1007/s00145-023-09489-9.

Fu, Chuanpu, Qi Li, and Ke Xu (Feb. 2023). *Detecting Unknown Encrypted Malicious Traffic in Real Time via Flow Interaction Graph Analysis*. URL: https://dx.doi.org/10.14722/ndss.2023.23080.

Gomez, Gibran et al. (Dec. 2022). *Unsupervised Detection and Clustering of Malicious TLS Flows*. URL: https://arxiv.org/abs/2109.03878v3.

Hefter, Alexander, Christoph Sendner, and Alexandra Dmitrienko (July 2023). *Metadata-based Malware Detection on Android using Machine Learning*.

Howey, Kyle D. et al. (Oct. 2024). *AI-QuIC: Machine Learning for Automated Detection of Misfolded Proteins in Seed Amplification Assays*. DOI: 10.1101/2024.10.16.618742. URL: https://doi.org/10.1101/2024.10.16.618742.

Jaeger, Benedikt et al. (Sept. 2023). *QUIC on the Highway: Evaluating Performance on High-rate Links*. URL: https://arxiv.org/abs/2309.16395v1.

Kempf, Marcel et al. (May 2024). "A Quantum of QUIC: Dissecting Cryptography with Post-Quantum Insights". In.

Khaleel, Yahya Layth et al. (May 2024). "Network and cybersecurity applications of defense in adversarial attacks: A state-of-the-art using machine learning and deep learning methods". In: *Journal of Intelligent Systems* 33, p. 20240153. DOI: 10.1515/jisys-2024-0153. URL: https://doi.org/10.1515/jisys-2024-0153.

Lai, Tin et al. (Jan. 2024). "Ensemble learning based anomaly detection for IoT cybersecurity via Bayesian hyperparameters sensitivity analysis". In: *Cybersecurity* 7, p. 44. DOI: 10.1186/s42400-024-00238-4. URL: https://doi.org/10.1186/s42400-024-00238-4.

Lande, Dmytro, Anatolii Feher, and Leonard Strashnoy (n.d.). *Cybersecurity in AI -Driven Casual Network Formation*.

Lee, Dong Jun et al. (July 2023). *Microfluidic Quaking -Induced Conversion (Micro -QuIC) for Rapid On-Site Amplification and Detection of Misfolded Proteins*. URL: https://doi.org/10.1101/2023.07.17.549283.

Nafiiev, Alan and Andrii Rodionov (June 2024). *Intelligent Data analysis methods in cybersecurity Malware Detection System Based on Static and Dynamic Analysis Using Machine Learning*.

Nawrocki, Marcin et al. (Dec. 2022). "On the Interplay between TLS Certificates and QUIC Performance". In: p. 10. DOI: 10.1145/3555050.3569123. URL: https://doi.org/10.1145/3555050.3569123.

Piskozub, Michal et al. (June 2021). *MalPhase: Fine-Grained Malware Detection Using Network Flow Data*.

S, Rama Mercy. and G. Padmavathi (June 2024). "Encrypted Access Mapping in a Distinctly Routed Optimized Immune System to Prevent DoS Attack Variants in VANET Architecture". In: *I. J. Computer Network and Information Security* 16.3, pp. 99–114. DOI: 10.5815/ijcnis.2024.03.08. URL: http://www.mecs-press.org/.

Shah, Ryan, Chuadhry Mujeeb Ahmed, and Shishir Nagaraja (Sept. 2022a). *Can You Still See Me?: Reconstructing Robot Operations Over End-to-End Encrypted Channels*. URL: https://arxiv.org/abs/2205.08426v2.

— (May 2022b). "POSTER: Can You Still See Me?: Identifying Robot Operations Over End-to-End Encrypted Channels". In: p. 3. DOI: 10.1145/3507657.3529659. URL: https://doi.org/10.1145/3507657.3529659.

Taylor, Vincent F. et al. (Apr. 2017). *Robust Smartphone App Identification Via Encrypted Network Traffic Analysis*. URL: https://arxiv.org/abs/1704.06099v1.

Ullah, Farhan, Gautam Srivastava, and Shamsher Ullah (Nov. 2022). "A malware detection system using a hybrid approach of multi-heads attention-based control flow traces and image visualization". In: *Journal of Cloud Computing* 11, p. 75. DOI: 10.1186/s13677-022-00349-8. URL: https://doi.org/10.1186/s13677-022-00349-8.

Wang, Yifan, Minzhao Lyu, and Vijay Sivaraman (Aug. 2024). *Characterizing User Platforms for Video Streaming in Broadband Networks*.

Wolsing, Konrad et al. (July 2019). "A Performance Perspective on Web Optimized Protocol Stacks: TCP+TLS+HTTP/2 vs. QUIC". In: p. 7. DOI: 10.1145/3340301.3341123. URL: https://doi.org/10.1145/3340301.3341123.

Xavier, Gonçalo, Carlos Novo, and Ricardo Morla (Sept. 2022). *Tweaking Metasploit to Evade Encrypted C2 Traf01c Detection*.

Zhang, Qianqian and Chi-Jiun Su (Oct. 2023). *Application-layer Characterization and Traffic Analysis for Encrypted QUIC Transport Protocol*. URL: https://arxiv.org/abs/2310.10676v1.

Annex

This annex provides supplementary material supporting the reproducibility, transparency, and technical completeness of the thesis. The content included here is not essential for the main narrative but is necessary for verification, replication, and further research.

Tools and Software Used

Zeek Network Security Monitor

Zeek was used for protocol-aware network traffic analysis and feature extraction from encrypted TLS 1.3 and QUIC traffic. Zeek scripts were employed to extract flow-level metadata without decrypting packet payloads.

Purpose in this thesis:

- Extraction of connection-level metadata
- Analysis of TLS handshake characteristics
- Monitoring of QUIC traffic behavior

Key extracted features include:

- Flow duration
- Packet counts and byte counts
- Directional traffic statistics
- Timing-based features

CICFlowMeter

CICFlowMeter was used to generate bidirectional flow features from packet capture (PCAP) files. The tool extracts statistical flow-based features that are commonly used in network intrusion detection research.

Purpose in this thesis:

- Conversion of raw PCAP files into structured CSV datasets
- Extraction of statistical traffic features
- Support for machine learning model training and evaluation

Example extracted features:

- Flow duration
- Inter-arrival times
- Packet length statistics
- Forward and backward packet ratios

Datasets

The datasets used in this thesis consist of encrypted TLS 1.3 and QUIC traffic captures containing both benign and malicious traffic.

Dataset characteristics:

- Network traffic captured in PCAP format
- Encrypted application-layer payloads
- Labelled traffic classes (benign / malicious)

Preprocessing steps:

- Flow extraction using Zeek and CICFlowMeter
- Removal of incomplete and corrupted flows
- Feature normalization
- Label encoding

GitHub Repository

All source code, scripts, and configuration files developed for this thesis are publicly available in the following GitHub repository:

GitHub Repository:
`https://github.com/vanditshah44/encrypted-traffic-classification`

The repository includes:

- Data preprocessing scripts
- Feature extraction pipelines
- Configuration files
- Documentation and usage instructions

Ethical and Legal Considerations

All network traffic data used in this thesis was collected and processed in accordance with applicable legal and ethical guidelines. No decrypted payload data or personally identifiable information was accessed or analyzed.

The analysis focuses exclusively on metadata and statistical characteristics of encrypted traffic to preserve user privacy.